

Warsaw, October 9, 2024

Decision

DKN.5131.1.2021

Based on Article 104 § 1 of the Act of June 14, 1960, the Code of Administrative Procedure (Journal of Laws of 2024, item 572), Article 7 paragraphs 1 and 2, Article 60, Article 101, and Article 103 of the Act on the Protection of Personal Data (Journal of Laws of 2019, item 1781), as well as Article 57 paragraph 1 letters a) and h) and Article 58 paragraph 2 letters d) and i), Article 83 paragraphs 1 – 3, Article 83 paragraph 4 letter a) in connection with Article 24 paragraph 1, Article 25 paragraph 1, Article 28 paragraphs 1 and 3, Article 32 paragraphs 1 and 2, and Article 34 paragraph 2 in conjunction with Article 33 paragraph 3 letters c) and d) and Article 83 paragraph 5 letter a) in connection with Article 5 paragraph 1 letter f) and Article 5 paragraph 2 of the Regulation of the European Parliament and of the Council (EU) 2016/679 of April 27, 2016, on the protection of natural persons in relation to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation) (OJ EU L 119 of May 4, 2016, p. 1, OJ EU L 127 of May 23, 2018, p. 2, and OJ EU L 74 of March 4, 2021, p. 35), hereinafter referred to as the "Regulation 2016/679", after conducting an ex officio administrative proceeding regarding the violation of personal data protection regulations by Mr. AB, conducting business under the name X, ul. (...) (as the data controller) and Ms. CD, Mr. EF, and Mr. GH, partners of the civil partnership Y, Al. (...) (as data processors), the President of the Personal Data Protection Office,

I. stating the violation by Mr. AB, conducting business under the name X, ul. (...), of the provisions:

a) Article 24 paragraph 1, Article 25 paragraph 1, and Article 32 paragraphs 1 and 2 of Regulation 2016/679, consisting of:

- failure to implement appropriate technical and organizational measures to ensure the security of personal data processing in IT systems and to protect the rights of data subjects, based on a risk analysis considering the state of technical knowledge, the cost of implementation, the nature, scope, context, and purposes of processing, and the risk of violation of the rights or freedoms of natural persons,
 - failure to implement appropriate technical and organizational measures to ensure regular testing, measuring, and evaluating the effectiveness of technical and organizational measures intended to ensure the security of personal data processing in IT systems, particularly regarding vulnerabilities, errors, and their possible consequences for those systems and the actions taken to minimize the risk of their occurrence,
 - failure to implement appropriate technical and organizational measures to ensure the ability to quickly restore the availability of personal data processed in IT systems and access to it in the event of a physical or technical incident,
- resulting in a violation of the principle of confidentiality (Article 5 paragraph 1 letter f) of Regulation 2016/679) and the principle of accountability (Article 5 paragraph 2 of Regulation 2016/679),

b) Article 28 paragraph 1 of Regulation 2016/679, consisting of the lack of verification of the data processor to ensure sufficient guarantees for the implementation of appropriate technical and organizational measures so that the processing meets the requirements of Regulation 2016/679 and protects the rights of data subjects,

c) Article 34 paragraph 2 in connection with Article 33 paragraph 3 letters c) and d) of Regulation 2016/679, consisting of the failure to provide data subjects with a description of the possible consequences of a personal data breach and a description of the measures taken or proposed by the controller to address the personal data breach,

1. imposes on Mr. AB, conducting business under the name X, ul. (...), for the violation of Article 5 paragraph 1 letter f), Article 5 paragraph 2, Article 25 paragraph 1, Article 28 paragraph 1, Article 32 paragraphs 1 and 2, and Article 34 paragraph 2 in connection with Article 33 paragraph 3 letters c) and d) of Regulation 2016/679, an administrative fine in the amount of 353,589 PLN (in words: three

hundred fifty-three thousand five hundred eighty-nine zlotys);

2. orders Mr. AB, conducting business under the name X, ul. (...), to adjust the processing operations to the provisions of Regulation 2016/679, by conducting a risk analysis of personal data processing, taking into account the state of technical knowledge, the cost of implementation, the scope, context, and purposes of processing, and the risk of violation of the rights or freedoms of natural persons, and based on it:

a) to implement appropriate technical and organizational measures to minimize the risks associated with the processing of personal data in IT systems, particularly arising from accidental or unlawful destruction, loss, modification, unauthorized disclosure, or unauthorized access to personal data transmitted, stored, or otherwise processed,

b) to implement appropriate technical and organizational measures to ensure regular testing, measuring, and evaluating the effectiveness of measures intended to ensure the security of personal data processing in IT systems,

c) to implement appropriate technical and organizational measures to ensure the ability to quickly restore the availability of personal data processed in IT systems and access to it in the event of a physical or technical incident, within 60 days from the date of delivery of this decision.

II. stating the violation by Ms. CD, Mr. EF, and Mr. GH, partners of Y s.c., Al. (...) of Article 28(3)(f) in connection with Articles 32(1) and (2) of Regulation 2016/679, consisting of the failure to assist the administrator in fulfilling his obligation to implement adequate technical and organizational measures ensuring the security of personal data processing, imposes on Mr. EF and Mr. GH, partners of Y s.c., Al. (...) and on Ms. CD, a former partner of Y s.c., all jointly liable, an administrative monetary penalty in the amount of 9,822 PLN (in words: nine thousand eight hundred twenty-two zlotys).

Justification

On December 3, 2019, Mr. AB, conducting business under X, ul. (...), related – according to the information provided on his website – to nationwide production “(...)” hereinafter referred to as the Administrator, made a preliminary notification to the President of the Personal Data Protection Office, hereinafter referred to as the President of UODO or the supervisory authority, regarding a personal data breach consisting of a ransomware attack carried out by unidentified perpetrators, as a result of which the availability of the following categories of personal data was lost, both of “(...) customers who have made a purchase [editor's note: from the Administrator] (...)” as well as former and current employees of the Administrator “(...) numbering about 200 (...): PESEL number, series and number of the identity card, first and last names, parents' names, date of birth, bank account number, residential or stay address, email address, phone number.” In the aforementioned notification of the personal data breach, the Administrator stated that – in his opinion – “(...) the cause of the breach was most likely human error – an employee (...)”, while the modus operandi of the perpetrators allowed the Administrator to assume that “(...) the purpose of encrypting the data was not their theft (...), but merely “(...) obtaining material benefits (...)”. The Administrator also indicated that due to the short duration of the incident and the fact that “(...) access to the encrypted data was obtained,” he did not find a high risk of infringement of the rights or freedoms of natural persons, and the technical and organizational security measures implemented before the occurrence of the personal data breach justified – in the Administrator's opinion – the lack of necessity to notify the data subjects about the fact of the breach of their personal data. In a supplementary notification made to the President of UODO on January 8, 2020, the Administrator maintained the previous argumentation, informing at the same time about notifying the data subjects about the occurrence of the personal data breach in the form of a public announcement available at the Administrator's company headquarters, while presenting the anonymized content of the notification sent to the data subjects regarding this breach.

The aforementioned notifications of the personal data breach became an impetus for the supervisory authority to assess the Administrator's fulfillment of the obligations imposed on him by the provisions of Regulation 2016/679 regarding the proper security of data and the organization of the personal data protection system.

In light of the above, the President of UODO, acting on the basis of Article 58(1)(a) and (e) of

Regulation 2016/679, by letter dated February 24, 2020, requested the Administrator to provide additional explanations in this matter, including, among others: 1) to provide the characteristics of the encrypted files, and primarily the file extension; 2) to provide the full content of the RTF file message, "(...) in which instructions were indicated for unlocking the encrypted data"; 3) to provide information on whether, in connection with the occurrence of the personal data breach, the Administrator considered reporting this incident to CSIRT NASK (incydent.cert.pl) in order to obtain broader information about the malware based on the submission of one of the encrypted files; 4) to indicate whether the Administrator conducted an explanatory procedure that allowed for the determination that personal data had not been disclosed to unauthorized persons; 5) to provide information regarding the analysis conducted by the Administrator of the personal data breach that established that the lack of availability of data did not pose a high risk of infringement of the rights or freedoms of natural persons; 6) to inform whether the Administrator implemented the measures declared in point 9B of the notification form dated January 8, 2020, aimed at minimizing the risk of a recurrence of the personal data breach, including, among others, establishing cooperation with a professional entity in the IT field, which was to conduct "(...) at least twice a year an additional independent audit [of the Administrator's IT infrastructure – ed. note] (...)", introducing "(...) a system (...) (...)", completing work aimed at establishing "(...) network segmentation (...)", or limiting its users' ability to "(...) interfere with the operation of antivirus software (...)."

In a letter dated March 5, 2020, in response to the aforementioned request from the President of UODO, the Administrator explained that the notification of the "(...) incident to CSIRT NASK (...)" was indeed within his area of interest, but he ultimately decided against this step. Nevertheless, the Administrator indicated that "(...) he conducted an explanatory procedure, but first focused on eliminating the effects of the breach (...)", in which "(...) the nature of the attack conducted (...)" indicated - in the Administrator's opinion - with a high probability solely the intention of "(...) extorting ransom for decrypting data, and not their further dissemination (...)". The Administrator noted that "(...) does not possess data that unequivocally excludes the possibility of data being accessed by unauthorized third parties during the breach (...)", while assuring that "(...) the majority of (...)" measures declared in point 9B of the personal data breach notification form dated January 8, 2020, have been successfully implemented, which limit the risk of a recurrence of the personal data breach, except for "(...) the introduction of the system (...)". Regardless of the above, the Administrator provided the content of the message contained in the RTF file, as well as the name and extension of the encrypted file, i.e. "(...)".

Based on the analysis of the content of the notification sent to the individuals concerned and the nature of the breach that occurred, its duration, the categories of data and categories of individuals affected by the breach, as well as the remedial measures applied, and in light of the additional explanations provided by the Administrator regarding the personal data breach in question, particularly due to the lack of details presented by the Administrator concerning the conducted explanatory proceedings and their results, including evidence that would substantiate the Administrator's appropriate findings for the actual identification of the malicious software's mode of operation, the President of the Personal Data Protection Office (UODO) concluded that there are insufficient grounds to assume that "(...) the purpose of encrypting the data was not their theft (...)". This assessment was primarily influenced by the Administrator's failure to provide details regarding the conducted explanatory proceedings and their results, particularly the lack of sufficient evidence of actions taken by the Administrator to genuinely determine the mode of operation of the malicious software.

In this light, acknowledging that there may have been a breach of confidentiality concerning the categories of personal data of the Administrator's employees and clients in the form of: PESEL number, series and number of the identity card, first and last names, parents' names, dates of birth, bank account numbers, residential or temporary addresses, email addresses, and phone numbers, which consequently poses a high risk of infringing the rights or freedoms of natural persons, the President of UODO, acting under Article 52(1) of the Act of May 10, 2018, on the Protection of Personal Data (Journal of Laws of 2019, item 1781), hereinafter referred to as the UODO, and Article

34(4) of Regulation 2016/679, requested the Administrator to resend the notification to the individuals concerned regarding the breach of their personal data protection. The authority noted that the notification sent to the individuals concerned did not meet the conditions specified in Regulation 2016/679 in that it did not contain information regarding the name and contact details of the data protection officer or the designation of another contact point from which more information could be obtained, a description of the possible consequences of the personal data breach, and a description of the measures taken or proposed by the Administrator to address the breach – including, where appropriate, measures to minimize its potential negative effects. In accordance with the provisions of Article 52(1) of the UODO and Article 34(4) of Regulation 2016/679, the President of UODO obliged the Administrator to inform the authority of the actions taken in the aforementioned scope within 30 days from the date of receiving the relevant request. Regardless of the above, acting under Article 58(1)(a) and (e) of Regulation 2016/679, the authority also called upon the Administrator to supplement the explanations previously provided by:

1) presenting the results of the explanatory proceedings referred to in point (...) of the letter dated March 5, 2020, particularly indicating the vulnerability that was exploited to carry out the attack in question, including how this breach occurred – whether it was caused by a human factor, such as opening an attachment in an email, and if so, whether the Administrator conducted an analysis aimed at determining the mode of operation of the malicious software, or whether the personal data breach was the result of a vulnerability existing in the IT system, and if so, indicating the duration of this vulnerability and any actions taken in connection with this fact;

2) providing information on whether, and if so, when and how the Administrator regularly tested, measured, and assessed the effectiveness of the technical and organizational measures aimed at ensuring the security of personal data processing.

In response to the aforementioned request from the President of UODO, the Administrator, in a letter dated April 10, 2020, indicated that he directly informed employees about the breach of their personal data protection; however, due to the “(...) extraordinary and objective situation related to the COVID-19 epidemic (...)”, “(...) the Administrator's clients were informed through a public announcement (...)”. He also provided the content of the notifications reformulated in connection with the occurrence of the personal data breach addressed to the individuals concerned. The Administrator, in describing the possible consequences of this breach, indicated the following negative effects associated with it: “(...) [d]ata that is the subject of the breach may be used for purposes such as attempting to obtain other personal data from you, or attempting to enter into a contract with you (for example, online sales) using that data, executing a hacking attack by sending a notification to your email or phone number. There is also a chance that you will receive commercial information, marketing, to which you did not consent.” In an attempt to convey to the individuals whose data is concerned a description of measures to minimize potential negative consequences of the incident of November 25, 2019, the Administrator advised these individuals to take the following actions: “(...) [d]o not respond to emails and texts from sources you are not sure of and do not open the links contained in them. This may result in your equipment being infected.” Furthermore, the Administrator, also referring to previous correspondence with the supervisory authority, informed that “(...) it has taken the following actions aimed at strengthening the security of processed personal data (...)”, among which the following should be mentioned: “(...) complete withdrawal from use of the system on which the infection occurred (...); updating operating systems to the latest available versions, including changing the operating system (...) to the system (...); basing access control to data processing processes, including personal data, on “(...)”, also by assigning users in the IT structure “(...) roles corresponding to their positions (...)”, while simultaneously limiting access to other network resources; (...) “(...) between access to applications on which users work and the database where personal and business data is stored (...); creating for network users “(...) (...)”. Regardless of the above, the Administrator noted that it had changed the work model by implementing the solution (...), while simultaneously closing “(...) the [IT – added by the translator] infrastructure from the outside (...); introducing (...); planning (...) “(...) (...)””. The content of the mentioned letter also emphasized the ongoing, gradual

exchange of “(...) (...) (...)” and the fact that “(...) users were deprived of the ability to control antivirus software (...)”, which after the changes “(...) can only be turned off by the IT team (...)”. According to further assurances from the Administrator, there was “(...) (...) (...)”, as well as “(...) software was implemented (...) (...)”, intended by the Administrator to “(...) (...)”. The Administrator also mentioned plans to appoint a data protection officer in its organization, “(...) who will be responsible for contacts with the UODO, but will also be able to propose a training plan for employees (...)” and the need for “(...) anonymization of database modules (concerning personal data of individual clients and employees), so that in the electronic system this data would be encrypted, and its reading would be possible only by a narrow group of employees who have codes to the decrypting program.”

In an attempt to determine the etiology of the subject data protection breach, in the aforementioned letter, the Administrator additionally indicated that, in its opinion, it was the result of “(...) the disabling of the licensed antivirus program A. by one of the employees (...), as a result of which “(...) the equipment was infected (...)”, “(...) user credentials were obtained (...)”, followed by the perpetrators remotely logging into the information system and consequently encrypting personal data. The Administrator also informed that for the above criminal action, “(...) the vulnerability of server B., which had not been updated for a long time,” was exploited, due to the failure to perform or improperly performed obligations by entities that had previously provided IT services to the Administrator. Finally, the Administrator also provided information regarding the reporting of the matter to CSIRT NASK. The information presented by the Administrator in this regard and contained in the previously conducted correspondence with the supervisory authority constituted, in the opinion of the President of the UODO, a sufficient basis for initiating ex officio administrative proceedings regarding the Administrator's violation of the provisions on personal data protection within the meaning of Regulation 2016/679, i.e. Article 5(1)(f), Article 5(2), Article 24(1), Article 25(1), Article 28(1) and Article 28(3), Article 32(1) and Article 32(2) as well as Article 34(2) in conjunction with Article 33(3)(c) and Article 33(3)(d) of Regulation 2016/679, of which the party was notified by a letter dated January 29, 2021. At the same time, in this notification, the President of the UODO called on the Administrator to provide additional explanations, including, among others: 1) indicating the service provision agreement and the personal data processing entrustment agreement concluded with entities in the IT sector, as mentioned in the letter of April 10, 2020, including the period of service provision, along with justification of how the Administrator verified the aforementioned entities in terms of ensuring sufficient guarantees for the professional provision of these services; 2) describing the organizational complexity of the Administrator, including providing, among others, the number of workstations, organization of work, number of employees servicing the aforementioned workstations; 3) providing information regarding the period of operation of the organization in the manner presented in the letter of April 10, 2020, in particular informing from when the Administrator had been using software B.; 4) indicating whether the Administrator had – as specified in the letter of April 10, 2020 – a server in its own infrastructure and whether these services were and are currently being provided by an external entity in the form of outsourcing, and in the case of a positive response, providing copies of service agreements, including the personal data processing entrustment agreement, concluded with that entity; 5) informing on what basis access to the Administrator's IT environment occurred before the occurrence of the subject data protection breach and whether a risk analysis regarding the security of personal data processing was conducted by the Administrator, along with presenting its results; 6) indicating the justification for granting permissions. administrative employees at workstations and thus enabling them to disable antivirus software; 7) indicating the names and dates of training conducted by the Administrator for employees regarding personal data protection regulations.

In response to the notification of the initiation of proceedings, in a letter dated February 16, 2021, the Administrator, addressing the issue of indicating the service provision agreement and the personal data processing entrustment agreement concluded with entities in the IT sector, informed that “(...) he concluded data processing entrustment agreements (dates of conclusion of agreements May 24, 2018) and service provision agreements with these entities. He emphasized that “(...) the service provision agreement was not concluded in writing; however, the parties to this agreement never had

any doubts that Y s.c. CD, EF, GH (hereinafter: Y) was responsible for full IT support since at least 2010, ensuring the security of digitally processed data and providing hardware solutions that meet the highest security standards.” Referring to the issue of verifying the processing entity in terms of compliance with the requirements of Regulation 2016/679, the Administrator indicated that the choice of the mentioned partner was dictated by its many years of experience gained in the field of implementation in organizations (...), which was reflected in its status of “(...) (...)”.

Describing its organizational structure, the Administrator explained that it has been conducting business activities since 1992 in the form of a sole proprietorship, in which each of the 30 employees in the organization – participating in personal data processing processes – acts according to the granted authorizations, performing their tasks on 33 workstations. Furthermore, the Administrator outlined a picture in which each of the computers is equipped with up-to-date antivirus software recommended by the entity providing IT services, where access to resources “(...) is protected by passwords (...)”, remaining at the exclusive disposal of the company’s staff members, and “(...) specialized entities providing IT services ensure the integrity and security of the computer system and the information contained therein.” The Administrator noted that although “(...) it is difficult from the perspective of 2021 to determine (...)” when specifically “(...) the change of environment, firewalls, or antivirus software occurred (...), according to his knowledge, “(...) the operating system B. [B. – ed. note] has been used in the Administrator’s enterprise since October 2010, while this program received support (...) until January 14, 2020.”

Regarding the location of the infected server in the subject attack, the Administrator informed that it was located within the structure of the enterprise itself, and its proper operation was overseen by the company Y s.c. Currently – according to the Administrator’s declaration – “(...) the server is managed by [another entity from the IT support sector – ed. note] Z Sp. z o.o.”

In the characterization of access rules to the company’s IT environment before the occurrence of the subject personal data breach, there were none related to solutions based on (...), and the risk analysis of such a designed system (privacy by design) “(...) was based on ongoing IT consulting provided by the company Y.” The Administrator simultaneously assured that at the time of the occurrence of the subject personal data breach, “(...) employees had the status of standard users, without administrative rights to the server (...),” and their level of knowledge regarding personal data protection regulations, acquired through participation in two training sessions conducted by the Administrator, namely “(...) on June 30, 2018, regarding: GDPR – general principles of applying new regulations and on May 20, 2020, regarding: GDPR and the Personal Data Protection Act in the functioning of the enterprise (...)” allowed – in the Administrator’s assessment – to conclude that the employed individuals are aware that “(...) it is not permissible to independently configure hardware or software settings.”

To supplement the explanations previously submitted in this case, the President of UODO, in a letter dated July 1, 2021, requested the Administrator to respond to the following issues: 1) to describe the procedures used by the Administrator for creating, storing, and testing backup copies both before and after the occurrence of the subject breach; 2) to indicate whether the Administrator effectively implemented firewalls (...), in accordance with the declarations contained in letters dated March 5 and April 10, 2020, along with the date of their introduction; 3) to provide a copy of the correspondence conducted – according to the Administrator’s declaration – regarding this matter with CSIRT NASK; 4) to indicate what rights the Administrator’s employees had at workstations; 5) to provide information on whether the new entity providing IT services to the Administrator, namely Z Sp. z o.o. based in M., conducted a security audit of the Administrator’s IT environment, which it was obliged to carry out under the provisions of point (...) of Annex C “(...)” to “(...)”, including presenting its results and informing whether they were taken into account by the Administrator in the risk analysis conducted by him for personal data processing processes; 6) to inform whether the Administrator conducted training for staff on personal data protection regulations in the second half of 2020 and in 2021, along with the dates and names of these trainings.

In the explanations dated August 16, 2021, the Administrator... submitted that backups are performed automatically, at 24-hour intervals, using (...) software (...), with

the use of software C. (...), where a "(...) summary report is generated for the administrators responsible for overseeing the backups." The Administrator also raised that "(...) at least the last 90 backups are stored locally (...)," while "(...) after each backup cycle, a replica of the backup is made to the repository held by Z. Sp. z o.o. (...)" Furthermore, "(...) at the remote repository, at least the last 7 restore points are stored." The Administrator also pointed out the suspension of work on the implementation of "(...) device (...) and the change in the method of environmental protection (...)", by implementing "(...) on all end-user computers [and servers with access for end-users – ed. note] software (...) in a version allowing for the analysis of all workstations." Moreover – according to the Administrator's declaration – users currently have no ability to influence the effectiveness of the aforementioned software, which has been "(...) set in the most aggressive manner, prioritizing security over the convenience of the end-user (...)", so as to "(...) actively block incoming connections from the analyzed endpoint (...)"

Referring to the issue of permissions that were held by the Administrator's employees on workstations at the time when the personal data breach occurred, the Administrator characterized them as "(...) standard user permissions." In relation to the audit conducted by Z. Sp. z o.o. based in M., the Administrator was informed of the fact that the aforementioned action was completed, which resulted in the creation of "(...)", which in the Administrator's intention is to serve as a reference point for setting further goals in the area of information security.

Regardless of the above, the Administrator admitted that in the second half of 2020 and in 2021 "(...) no additional training [on personal data protection regulations – ed. note] was conducted (...)", however, the educational activities carried out so far in this regard have, in his opinion, resulted in a proper "(...) increase in the awareness of the Administrator's employees in the area of personal data protection." The Administrator also provided the content of the correspondence exchanged with CSIRT NASK regarding this matter.

Regardless of the above, in a letter dated November 9, 2021, the Administrator again referred to the causes of the personal data breach, identifying them as the result of human error, "(...) which could not be avoided, despite taking actions aimed at protecting personal data (...)", and which materialized due to random reasons on November 25, 2019, "(...) during modernization works (...)" and during the period when there was a transfer of "(...) responsibilities between two companies providing [IT services – ed. note] for company X (...)". The Administrator also highlighted the problem that, in his opinion, every organization struggles with in its daily operations, concerning the human factor as a risk factor that cannot be completely eliminated "(...) even by extraordinary actions of the employer (...)", citing a number of cases drawn from the history of his organization, which are examples of actions by staff that clearly deviated from the procedures regarding personal data protection in force in the Administrator's organization.

The findings made during this proceeding allowed for the conclusion that each of the partners of Y s.c. (Al. (...)), hereinafter also referred to as the Data Processor, was also responsible for the process of processing personal data covered by the personal data breach. Consequently, given the fulfillment of the conditions specified under Article 28 of the Act of June 14, 1960, the Code of Administrative Procedure (Journal of Laws of 2024, item 572), the President of UODO considered that in this case there is a justified need for the authority to assess the performance by Ms. CD, Mr. EF, and Mr. GH of the obligations of the Data Processor, which the Administrator entrusted based on § 2 point 1 of the agreement concluded on May 24, 2018, "(...)" for processing on his behalf and for his benefit the personal data of his "(...) employees, temporary workers, contractors, family members of employees, interns and trainees, contractors (...)," of which the parties were duly notified on June 10, 2022. It should be noted that according to the content of the letter presented by the Data Processor dated May 24, 2022, along with subsequent annexes, Ms. CD – in accordance with the document dated December 28, 2021, "(...)" – left "(...)" [as of] December 31, 2021, from the company Y S.C. (...)"

Regardless of the above, acting under Article 58(1)(a) and (e) of Regulation 2016/679, the President of UODO summoned on June 10, 2022, each of the individuals who were partners of the civil partnership Y. (Al. (...)) at the time of the personal data breach, namely Ms. CD, Mr. EF, and Mr. GH to: 1) submit

the security policy in effect at Y s.c. from May 24, 2018, to December 3, 2019, affecting the processes of processing personal data entrusted by the Administrator; 2) characterize the actions taken by Y s.c. from May 24, 2018, to December 3, 2019, aimed at assisting the Administrator in fulfilling his obligations specified in Articles 32 – 36 of Regulation 2016/679, including indicating whether Y s.c. conducted a security audit of the Administrator's IT infrastructure, and in the case of a positive response, was to provide the date and results of the evaluation conducted, while in the case of a negative response, was to indicate the reasons for not conducting such a check; 3) presentation of a description of the reasons for the occurrence of the security incident on November 25, 2019, which resulted in a breach of the protection of personal data processed by the Administrator; 4) provision of information regarding the permissions held by users of the Administrator's IT infrastructure to the infected server both before and after the occurrence of the aforementioned personal data breach; 5) indication of the date of termination of cooperation between the Administrator and Y s.c.

In the joint statements submitted to the supervisory authority on June 27, 2022, and July 8, 2022, the aforementioned partners of the civil partnership Y indicated the following: 1) "(...) The company Y s.c. does not have and has not had a signed contract for the administration of the IT infrastructure in company X," being responsible "(...) for providing the database server, licenses, implementation, and maintenance work related to system d., hence "(...) it has within the Administrator's IT infrastructure the rights to manage system d."; 2) "(...) from May 24, 2018, to December 3, 2019 (...)" a number of actions were taken to assist the Administrator in fulfilling its obligations specified in Articles 32-36 of Regulation 2016/679, in accordance with the data processing entrustment agreement between the two entities dated May 25, 2018, namely: "(...) - on June 25 and 27, 2019, a backup check was performed, unnecessary USB drives were disconnected, and backup configuration was made to the location indicated by the Administrator on server N., which was not provided, configured, and managed by Y s.c.; - on September 16, 2019 [Y s.c. – added by the author] provided the Server (...), along with licenses B. for the needs of system d.; - on November 13, 2019, an offer for a Router and UPS was submitted, after acceptance of the offer, on November 20, 2019, the equipment was physically delivered, but installation was not performed at the headquarters of company X (...); 3) "(...) after the occurrence of a ransomware attack on the Administrator's IT infrastructure from November 25 to December 3, 2019, [Y, Al. (...) – added by the author] the following actions were taken: disconnection of the server from the network; provision of antivirus software licenses A.; decryption of the database; scanning of computers from branches and headquarters; installation of new (...) + basic configuration + (...); installation of the system on the new server; system configuration and installation d. - database restoration; initiation of case analysis; scanning with newly purchased software A. of the server;" 4) "(...) The company Y s.c. did not conduct a security audit of the Administrator's IT infrastructure, and the reason was the lack of such an order from the Administrator and it was not included in the data processing entrustment agreement concluded on May 24, 2018." 5) according to the assessment of the Data Processor, made based on "(...) actions taken to recover the availability of data lost by the Administrator (...) the main reasons [for the occurrence of the personal data breach – added by the author] were the negligence of employees regarding compliance with the rules for using IT equipment within company X."

At the same time, the Data Processor presented the content of the security policy in force in its organization "(...) at the time of the occurrence of the incident" [of the personal data breach – added by the author] and submitted a copy "(...)" "(...) for the purpose of fulfilling [this – added by the author] agreement regarding the operation, exploitation, and maintenance of system d. in the Administrator's enterprise, and the proper fulfillment of obligations towards legally empowered state authorities," indicating that "(...) the above Data Processing Agreement has not been terminated by either party and is still in effect."

To supplement the explanations previously submitted in the course of this administrative proceeding, the President of UODO requested the Administrator on May 25, 2023, pursuant to Article 58(1)(a) and (e) of Regulation 2016/679 to: 1) indicate the server on which the personal data breach occurred; 2) inform whether the system "d." was hosted on a server using software (...);

Moreover, considering that the Administrator in point 3 of the letter dated April 10, 2020, stated, among other things, that "(...) The previous company (whose services the Administrator was not satisfied with due to the lack of timely provision of maintenance services and security system audits) was replaced in late September and early October 2019 by the company Y s.c.," the authority requested the disclosure of the entity that provided security services for the IT systems to the Administrator before the partners of the civil partnership Y and called for an indication of whether cooperation with the partners of Y s.c., Al. (...), had been terminated, and in the case of a positive response, asked the Administrator to provide the date of termination of this cooperation, including the data processing entrustment relationship.

Regardless of the above, the President of UODO, in letters dated May 25, 2023, summoned both former and current partners of the civil partnership Y, namely Ms. CD, Mr. EF, and Mr. GH to: 1) inform whether the server delivered on September 16, 2019 (...) was the server on which the personal data breach occurred, and in the case of a negative response, to indicate the server involved in this breach; 2) indicate what licenses were provided by Y s.c. (Al. (...)) for the needs of system d.; 3) informing whether system d. was hosted on a server using software E.

In response to the above questions, the aforementioned partners of the civil partnership Y, in consistent statements submitted to the supervisory authority on June 5, 2023, indicated the following: 1) "(...) The data protection violation in question occurred on a different server. The server on which the violation occurred is Server (...)."; 2) "(...) For the purposes of system d., Y s.c. provided X with the following licenses: d. (...) - 1 piece, d. (...) - 2 pieces, d. (...) - 1 piece, d. (...) - 23 pieces, d. (...) - server license, d. (...) - server license, add-on to system d. (...), add-on to system d. (...), add-on to system d. (...), M. (...) - 1 piece, (...) - 15 pieces, (...) - 10 pieces, M. (...) - 35 pieces, (...) - 1 piece, E. - 20 pieces."; 3) "(...) On the server using software E., server F. was installed with a database from which system d. operated. The installation of the client application d. was performed on users' computers.".

On the other hand, the Administrator addressed the questions posed to him by the President of the UODO on May 25, 2023, only in a letter dated July 7, 2023, despite having submitted a written commitment to the authority on June 5, 2023, "(...) to submit the above-mentioned response by June 15, 2023.". Nevertheless, he explained that: 1) "(...) The incident concerning data protection occurred on the server: (...)."; 2) "(...) On the server using software E., server F. was installed with a database from which system d. operated. The installation of the client application e. was performed on users' computers."; 3) "(...) In a letter dated February 16, 2021, the Administrator indicated that Y s.c. CD, EF, GH (hereinafter Y) was responsible for full IT support since at least 2010, ensuring the security of digitally processed data and providing hardware solutions meeting the highest security standards.

On the other hand, V s.c. IJ, KL (hereinafter V) dealt with issues related to alarms, Wi-Fi networks, or telephone connections."; 4) "(...) The Administrator did not terminate the contract with Y as he still collaborates with this entity to some extent.".

In an attempt to comprehensively consider the evidence gathered in this administrative proceeding and the inconsistencies arising in connection with this fact regarding the findings related to the server on which the data protection violation occurred, the President of the UODO sent letters dated September 20, 2023, to all parties of this proceeding requesting unequivocal information on whether system "d." was hosted on server "(...)", using software E., and in the case of a negative response, to indicate the name of the software used to operate the server on which the data protection violation occurred.

In response to the question posed by the authority, both former and current partners of the civil partnership Y, as well as the Administrator, provided identical and precise explanations on September 29, 2023, and October 3, 2023, respectively, stating, "(...) System >>d.<< was hosted on server "(...)", using software E.".

After reviewing all the evidence collected in the case, the President of the Office for Personal Data Protection considered the following: I. Violation of the provisions of Article 5(1)(f), Article 5(2), Article 24(1), Article 25(1), and Article 32(1) and (2) of Regulation 2016/679.

I.1. Risk management for personal data processing operations. The supervisory authority, in the notification dated January 29, 2021, regarding the initiation of administrative proceedings, indicated that the Administrator failed to fulfill, among others, the obligation arising from Article 32(1) of Regulation 2016/679, which involves selecting appropriate technical and organizational measures to ensure the security of processed data, including the ability to continuously ensure the confidentiality, integrity, availability, and resilience of processing systems and services, thereby failing to meet his obligations regarding ensuring and demonstrating compliance of processing with the requirements of Regulation 2016/679, as referred to in Article 24(1) of Regulation 2016/679, and the obligation to effectively implement data protection principles, as specified in Article 25(1) of Regulation 2016/679, and consequently violated the principle of integrity and confidentiality specified in Article 5(1)(f) of Regulation 2016/679, which imposes on the Administrator the obligation of due diligence in ensuring that personal data processing processes have an appropriate (in relation to the risk) level of security.

Considering the broad scope of categories of personal data subjected by the Administrator to processing operations, which also includes data enabling the unequivocal identification of individuals, i.e., PESEL number, and the categories of individuals to whom this data pertains, in order to properly fulfill the obligations imposed by the aforementioned provisions of the regulation, the Administrator was all the more obliged to take actions ensuring an adequate level of protection for personal data by implementing appropriate technical and organizational measures.

There is no doubt that according to the established approach to risk in the provisions of Regulation 2016/679 (risk-based approach), it is the Administrator who bears the burden of initiating processes of identification and assessment of risk factors and, on that basis, formulating his own strategy for its mitigation. An incorrect assessment of the level of risk or, worse, its absence, prevents the application of appropriate security measures for a given resource, which inherently contributes to increasing the likelihood of negative consequences materializing for individuals whose data is being processed. in the context of a specific process. In light of the above argumentation, it should be pointed out that Regulation 2016/679 introduced an approach in which risk management is the foundation of activities related to the protection of personal data and is characterized as an ongoing process. A key condition for demonstrating compliance with the requirements imposed on administrators, in accordance with the principle of accountability referred to in Article 5(2) of Regulation 2016/679, remains not only the one-time implementation by them of technical and organizational measures to ensure an appropriate level of protection for personal data processing processes but also—within the framework of a dynamic approach—the provision of continuous monitoring of the level of threats in relation to the adequacy of the implemented safeguards. The administrator is therefore obliged to conduct a detailed analysis of the personal data processing processes carried out and to comprehensively assess potential threats to the privacy of the individuals to whom the data pertains, and then to apply measures that will be adequate to the assessed risk. Consequently, it should be acknowledged that risk analysis forms the basis for appropriate management of possible vulnerabilities, understood as a weakness or gap in safeguards that, if exploited by a given threat, can disrupt the functioning of a given organization and even lead to security incidents or breaches of personal data protection.

There is no doubt that in the factual circumstances of this case, the main risk associated with the processes of personal data processing carried out by the Administrator should be identified with the threat stemming from the possibility of compromise, through the use of malicious software, its IT infrastructure, the initiation of foreign processes within it, and the commencement of the encryption process to obtain financial benefits in exchange for subsequent decryption of the data, i.e., ransomware.

The key method of prevention against such an attack is the use of up-to-date software for all elements of the IT infrastructure. Relating the above observation to the circumstances of the case at hand, it should be pointed out that the presented factual state constitutes a clear exemplification of a state contrary to that postulated by the provisions of Regulation 2016/679. The findings made during these proceedings unequivocally demonstrate that the Administrator, over an extremely wide time frame, at least since the date of the commencement of the application of the provisions of Regulation 2016/679,

i.e., since May 25, 2018 (adopting this perspective seems to be the most relevant for assessing the Administrator's compliance with the principle of accountability), utilized outdated versions of server B for the implementation of personal data processing processes, despite the fact that—as he himself noted in a letter dated February 16, 2021—“(…) this program was supported by E. until January 14, 2020.” On the contrary, the evidence gathered in this case does not show that the Administrator utilized the possibility of conducting current updates of server B during the period of technical support offered by the software producer. In this light, the sequence of events that took place on November 25, 2019, in the form of “(…) infection of the equipment (…)”, leading to the acquisition of “(…) user credentials, which allowed for remote login and the commencement of the encryption process,” should not raise any doubts, as it constituted the materialization of a long-standing high-risk state of potential data protection breaches, caused by the fact that the Administrator based personal data processing processes on IT architecture that, due to a lack of due diligence in conducting periodic updates, had a number of commonly known security vulnerabilities.

Importantly, in letters dated April 10, 2020, and February 16, 2021, the Administrator admitted that based on the conducted proceedings aimed at determining the causes of the occurrence of the data protection breach in question, “(…) assumes that a vulnerability of server B was exploited, which had not been updated for a long time,” despite the fact that “(…) this program was supported by E. until January 14, 2020.” From the above statement, it follows that the event of November 25, 2019, was a logical consequence of the Administrator's actions and evidenced his gross negligence, manifested both in his undertaking of personal data processing operations without identifying the risks associated with the data processing processes occurring in his organization and in the lack of regular testing, measuring, and evaluating the technical and organizational security measures implemented for these processes (which the Administrator was obliged to comply with at least since the date of the commencement of the application of Regulation 2016/679), despite having knowledge of the updates offered by the software producer. Consequently, it should be acknowledged that the Administrator, in implementing technical and organizational measures to ensure the security of personal data processing processes in his organization, was *priori* deprived of an effective tool for assessing whether they were sufficient, and the lack of periodic checks of the implemented tools and their assessment in terms of risk only exacerbated this state of ignorance.

There is no doubt that one of the key elements of risk analysis, alongside the identification of resources to be protected in the processing area, is, among other things, the identification of possible types of threats related to the aforementioned processing areas and

****Assignment of Appropriate Levels.** Meanwhile, in the evidence gathered during these proceedings, one can vainly search for any mention of actions undertaken by the Administrator aimed at conducting a relevant risk evaluation, which is inherently linked to the data processing operations carried out in their organization, not to mention the consideration by them of the likelihood of the threat associated with a cybercriminal attack on the IT infrastructure for the purpose of encrypting the personal data processed therein and obtaining material benefits for their subsequent decryption.**

****Undoubtedly,** the obligation to ensure the security of processed data, arising *inter alia* from Article 32(1) of Regulation 2016/679, constitutes the foundation of an effective personal data protection system. Regulation 2016/679, by introducing a risk-based approach, simultaneously indicates in Article 32(1) the criteria based on which the administrator should select appropriate technical and organizational measures to ensure a level of security corresponding to that risk. Thus, in addition to identifying the risk of infringement of the rights or freedoms of natural persons, one must also take into account the state of technical knowledge, the cost of implementation, and the nature, scope, context, and purposes of processing. Consequently, it should be recognized that the selection of security measures should be conditioned by the circumstances and conditions of data processing as well as the likelihood and severity of events that may lead to the infringement of the rights or freedoms of the individuals whose data is being processed.**

****It should be emphasized that the security measures, selected with consideration of the criteria resulting from Article 32(1) of Regulation 2016/679, for their effectiveness, understood as proper**

protection of the processes of personal data processing, must be based on a comprehensively conducted risk analysis, i.e., taking into account all real threats occurring in the given context of personal data processing, which was clearly lacking in this case. As has already been indicated, the Administrator did not provide any evidence that would substantiate the fact that they conducted a comprehensive risk analysis both before and after the commencement of personal data processing, thus also considering the likelihood of a ransomware attack, which they were obliged to do in accordance with the accountability principle arising from Article 5(2) of Regulation 2016/679. Clearly, one cannot consider the risk analysis designed by the Administrator of the system in a holistic manner, which "(...) was based on ongoing IT consultancy provided by company Y." In this context, it should therefore come as no surprise that due to the Administrator's inability to select security measures adequate to the existing threats, the security measures applied in their infrastructure, as presented, for example, in point 9A of the supplementary form for reporting a personal data breach dated January 8, 2020, i.e., "(...) Entering into data processing agreements with processors, limited authorizations for employees, computers having individual user accounts and passwords, screen savers, password changes, use of antivirus software, firewall, server location in an inaccessible place for unauthorized persons, alarm system, use of security company services outside working hours," in the event of an attack using the malicious software "M.", proved ineffective. At the same time, there is no doubt that this unfavorable state of affairs could have been avoided by the Administrator if the existing personal data protection system in their organization had been based on real premises, thus particularly on a thoroughly conducted and cyclically repeated risk analysis (cf. judgment of the WSA in Warsaw of May 13, 2021, case file II SA/Wa 2129/20; judgment of the WSA in Warsaw of October 5, 2023, case file II SA/Wa 502/23).**

As previously demonstrated, the Administrator did not identify the threat associated with the possibility of breaching the security of the IT system used in the processes of personal data processing by both their former and current employees and contractors, and subsequently encrypting their data. In this context, it must therefore raise even more concern and astonishment – given the lack of any evidence provided by the Administrator documenting the actions taken by them, in accordance with the accountability principle arising from Article 5(2) of Regulation 2016/679 – the omission of conducting a general risk analysis regarding the subject personal data breach, thus considering the risk of compromising their IT infrastructure using malicious software, through the workstation of one of their employees. According to the declaration made by the Administrator in the letter dated November 9, 2021, the decisive "(...) cause of the incident that occurred in November 2019, which initiated the administrative proceedings conducted by the President of the Personal Data Protection Office [in this matter – ed. note] was (probability bordering on certainty) human error (...)" (incidentally, the main cause of the occurrence of the subject personal data breach was recognized, in the unanimous opinion of the partners of Y s.c., i.e., the data processor responsible towards the Administrator "(...) for full IT support since at least 2010, ensuring the security of digitally processed data and providing hardware solutions that meet the highest security standards" precisely "(...) the negligence of employees regarding compliance with the principles of equipment use."

INFORMATION TECHNOLOGY WITHIN COMPANY X. It is clear that a certain remedy for the possibility of a recurrence of a situation similar to that which occurred on November 25, 2019, can be considered the technical and organizational security measures widely described by the Administrator, among others, in the letter dated April 10, 2020, which were cited on pages 7 and 8 of the justification for this decision. Nevertheless, the evidence gathered in this case does not provide grounds to conclude that those mitigating measures against the risk of a recurrence of personal data breaches were implemented with due regard to the principles of logic and life experience.

Based on the established evidence in the course of these proceedings, it is also impossible to unequivocally determine whether the remedial measures implemented by the Administrator after the occurrence of the personal data breach were based on any security tests of the resources he possessed. The mere mention in the Administrator's explanations from August 16, 2021, of a security audit conducted by Z Sp. z o.o. based in M. does not suffice to demonstrate that such tests were carried out. This audit resulted in the creation of "...", which the Administrator intended to serve only

as a reference point for setting further goals in the area of the company's IT security, especially since the Administrator did not disclose the content of the aforementioned document, despite a request made to him in this regard on July 1, 2021.

According to the supervisory authority, a comprehensive identification of potential threats to personal data processing processes and their appropriate classification, followed by the implementation of appropriate technical and organizational measures to ensure that personal data processing processes are afforded an adequate level of protection, constitutes, alongside their proper verification both before and after the initiation of those processes, the foundation upon which the personal data protection system in any organization should be built. In this context, it should be noted that the Administrator did not present any evidence clearly substantiating the fact that he implemented technical and organizational security measures after the occurrence of the personal data breach, taking into account the risks associated with the possibility of breaching the security of the IT system used by the Administrator in personal data processing processes and subsequently encrypting them. Therefore, this constitutes a circumstance in which he is unable to demonstrate, in a manner that leaves no doubt, in accordance with the accountability principle referred to in Article 5(2) of Regulation 2016/679, that the selection of these measures was not made arbitrarily, i.e., without due consideration of the risks arising from the context of the processing processes being carried out. Consequently, such implemented measures mitigate the likelihood of a personal data breach, exposing the Administrator to a real danger that the actions he has planned will ultimately constitute an inadequate response to the inherent risk to personal data processing processes. Furthermore, his continued failure to conduct regular evaluations of these measures (there is no evidence that such actions were undertaken by the Administrator at all) and the required updates creates a real threat of a personal data breach occurring in the future.

In light of the above argumentation, in the opinion of the President of the UODO, the inability of the Administrator to provide documentation relating to the analyses he conducted does not provide grounds for concluding that risk mitigation occurred both before and after the occurrence of the personal data breach. An analysis of the evidence gathered in the course of these proceedings clearly indicates that the Administrator did attempt to assess the security status of the IT systems used for processing personal data (see: "..."), however, he did not disclose either the content of the mentioned document or the date of its preparation. Only from the date of the letter, which contained a declaration of its creation, i.e., August 16, 2021, can it be inferred that it pertains to the state of the IT infrastructure functioning in the Administrator's organization long after the occurrence of the aforementioned attack using the M. malware. Thus, in the absence of the Administrator presenting the results of the analyses conducted, it is impossible to assess their completeness. A reliable description of all vulnerabilities and resistances to attempts to breach security due to unauthorized actions by third parties and malware would be a prerequisite for making appropriate qualifications in this regard. For this reason, the mere mention of the evaluation of the IT environment in company X conducted by Z Sp. z o.o. at the request of the Administrator holds no evidentiary weight and certainly cannot constitute evidence of a risk analysis conducted by him, especially since the Administrator himself perceives the aforementioned document as a specific reference point based on which "(...) goals have been set for implementation in the coming years," and thus – purely hypothetically – it can only be treated as an element of future risk analysis.

In an attempt to recap the previous considerations, it should be noted that the analysis of the presented factual state unequivocally excludes the proper fulfillment by the Administrator of the accountability principle (Article 5(2) of Regulation 2016/679) both before,

I.2. Technical and organizational measures used to ensure the protection of processed personal data. As demonstrated thus far, the circumstances revealed in this case highlight the necessity for data processing administrators to base their processes on a risk-based approach, understanding its scale and the likelihood of negative consequences for the rights or freedoms of the individuals whose data is concerned. Thus, the administrator's failure to conduct an analysis regarding the data processing processes that encompasses all the elements specified in recitals 76 and 83 of Regulation 2016/679

unequivocally indicates the inability to manage the objectively existing risks associated with personal data processing.

The inability to continuously ensure confidentiality, integrity, availability, and resilience of processing systems and services based on the technical and organizational security measures implemented by the administrator constitutes a breach of the obligations defined in Article 24(1), Article 25(1), and Article 32(1) of Regulation 2016/679. At the same time, the failure to fulfill the aforementioned excludes the possibility for the administrator to demonstrate compliance with the rules expressed in Article 5(1)(f) of Regulation 2016/679, in accordance with the principle of data security, and consequently also the accountability principle defined in Article 5(2) of Regulation 2016/679 (see the judgment of the Administrative Court in Warsaw of August 26, 2020, case no. II SA/Wa 2826/19, and February 10, 2021, case no. II SA/Wa 2378/20).

In this context, it must be unequivocally acknowledged that using operating systems and information systems for personal data processing activities without exercising due diligence to ensure they are updated to the latest stable version significantly lowers the security level of the processes carried out in this manner. The absence of built-in and updated security measures particularly increases the risk of infection by malware and attacks through the emergence of new vulnerabilities.

To ensure an appropriate level of security for personal data processing activities, it remains necessary for administrators to design technical measures in accordance with the principle of least privilege, taking into account the classification of individuals employed in their organization. This means not only implementing appropriate restrictions on end-user permissions but – equally importantly – exercising oversight over their actions. However, only the connection of the administrator's aforementioned measures with regular investment in the competencies of individuals employed in their organization, both in terms of data protection regulations and knowledge regarding threats associated with their functioning on the Internet, constitutes the completeness of the measures and means implemented by the administrator to ensure adequate protection for personal data processing activities.

level of protection.

The requirements specified in Articles 24(1) and 25(1) of Regulation 2016/679, addressed solely to controllers, manifest as an obligation for them to implement technical and organizational measures. This action should be regarded not as a one-time activity but as a process within which the controller reviews and, if necessary, updates previously adopted safeguards. Such an assessment should apply not only to technical measures but also to organizational measures in the form of procedures implemented by the controller concerning the processing of personal data, including procedures for making changes to the information systems used for processing personal data. Regular evaluation of the aforementioned procedures, in accordance with the requirement arising from Article 32(1)(d) of Regulation 2016/679, allows the controller to verify whether these procedures are lacking, and if not, whether such a procedure is effective, i.e., whether it ensures that appropriate actions are taken to protect personal data during the process of making changes to the information system and whether it is being adhered to by those responsible for implementing these changes. It should therefore be noted that ensuring oversight and monitoring of information systems, for which care has been entrusted to external entities, is one of the fundamental organizational measures that the controller should effectively implement to ensure the security of personal data in accordance with the requirements arising from Regulation 2016/679 (cf. judgment of the Administrative Court in Warsaw of June 6, 2023, case file II SA/Wa 1939/22, judgment of the Administrative Court in Warsaw of June 21, 2023, case file II SA/Wa 150/23).

As a result of the controller's failure to comply with the above principles, he cannot effectively demonstrate that the risks inherently associated with the processing of personal data carried out on his behalf and for his benefit were continuously minimized by him. A contrario, the application of appropriate security standards in the operation of information systems used by the controller in the processes of personal data processing, including their verification for security, and in particular compliance with the requirements arising from Article 24(1), Article 25(1), and Article 32(1) and (2) of Regulation 2016/679, as well as effective verification of the actions of the processor in this regard, can

significantly minimize this risk. The failure of the controller to implement procedures for making changes to the information systems used for processing personal data deprived him of the tools for effective verification of the means and methods of fulfilling the obligations by the processor "(...) regarding the management, operation, and maintenance of the system d. in the enterprise of the controller (...)". It should be pointed out that the controller did not supervise at any stage of the changes being made, both before and after November 25, 2019, whether these changes were actually proceeding correctly and whether the processed personal data were secured against unauthorized access, and yet such supervision constitutes the implementation of an organizational measure to ensure the security of personal data processing processes. The above omissions on the part of the controller have adversely affected his ability to minimize the objective risk of unauthorized access to the data processed in this system. Consequently, the demonstrated negligence, which constitutes an example of the controller's failure to fulfill the obligations addressed solely to him as specified in Articles 24 and 25 of Regulation 2016/679, must meet with a proportional response from the supervisory authority, regardless of the fact that they did not constitute a direct cause of the specific personal data breach, which was the infection of one of the employee computers "(...) (...) (...) ", "(...) due to (probably accidental) disabling of the licensed antivirus program A. by one of the employees of the controller."

The evidence collected in the case does not show that the controller conducted audits, including inspections, at the processor to verify whether the partners Y s.c. properly fulfill their obligations arising from Regulation 2016/679, including whether they ensure the application of the measures required under Article 32 of this legal act. The possibility of conducting such audits, including inspections, arises from Article 28(3)(h) of Regulation 2016/679, according to which the data processing agreement must stipulate that the processor provides the controller with all necessary information to demonstrate compliance with the obligations specified in this article and allows the controller or an auditor authorized by the controller to conduct audits, including inspections, and contributes to them. This provision thus equips controllers with the tools that allow them to demonstrate that the data processing entrusted will comply with the provisions of Regulation 2016/679, and they will avoid liability for its violation. At the same time, it should be emphasized that conducting audits, including inspections, by the controller at the processor should be regarded as one of the most significant security measures that the controller should apply to properly fulfill his obligations arising from Article 32(1) of Regulation 2016/679, which was lacking in the discussed case. This fact is clearly evident from the explanations submitted by the controller on April 10, 2020, in which he notes that only after conducting an explanatory procedure regarding the subject data protection violation, it " (...) turned out that this entity [Y s.c. – added by the author] also did not fulfill its obligations (...)". Meanwhile, the Administrator should have been aware, while using the services of the Data Processor, whether and how the entity to which it entrusted the processing of personal data meets the requirements set out in Regulation 2016/679. There is no doubt that the most effective way to acquire this knowledge would have been for the Administrator to utilize the option offered in § (...) connecting it with the Data Processor to conduct appropriate audits within the processor's organization, including inspections. However, the Administrator did not implement such security measures, which consequently also constitutes a violation of Article 32(1)(d) of Regulation 2016/679. Furthermore, as demonstrated above, the application of the aforementioned measures is linked to the data controller's obligation arising from Article 28(1) of Regulation 2016/679, which in turn means that its implementation must also confirm whether the data processor continues to provide guarantees for the implementation of appropriate technical and organizational measures to ensure that the processing meets the requirements of Regulation 2016/679 and protects the rights of the data subjects. The lack of audits, including inspections, within the Data Processor consequently signifies a violation by the Administrator not only of Article 28(1) of Regulation 2016/679 but also of Article 25(1) of Regulation 2016/679, which obliges it to implement appropriate technical and organizational measures, both when determining the methods of processing and during the processing itself. The continuity embedded in this obligation may therefore manifest itself, among other things, in the necessity to ensure regular monitoring of the applied security measures and to maintain ongoing supervision over the data processor, through, for example, audits and inspections, as mentioned in Article 28(3)(h) of Regulation

2016/679, which was lacking in the circumstances of this case. Despite the fact that – as evidenced by the established evidence – the data processing entrustment relationship between the Administrator and the partners of Y s.c. has not been formally terminated to this day, the Administrator has not presented any evidence supporting the conduct of audits within the Data Processor, including inspections.

In light of the above argumentation, the failure of the Administrator to implement appropriate procedures ensuring the security of personal data processed in the IT system d. and the lack of supervision over the Data Processor " (...) in terms of the operation, exploitation, and maintenance of the system d. in the Administrator's enterprise (...)" determines the violation of the requirements set forth in Article 32 of Regulation 2016/679.

I.3. Regular training of employees within the Administrator's structure. It should be pointed out that the analysis of the case of the subject data protection violation once again clearly shows – which seems to be recognized by the Administrator itself – " (...) that in similar situations, the weakest link remains the human factor (...)" . However, the thesis raised by it in the letter dated November 9, 2021, about human error, " (...) which could not be avoided [on November 25, 2019 – added by the author], despite taking actions aimed at protecting personal data (...)", no longer finds any reflection in the facts. It must be noted that according to the information provided on February 16, 2021, the Administrator " (...) conducted a total of two trainings [on data protection regulations – added by the author]: on June 30, 2018, regarding: GDPR - general principles of applying new regulations and on May 20, 2020, regarding: GDPR and the Personal Data Protection Act in the functioning of the enterprise."

From the above, it follows unequivocally that prior to the occurrence of the subject data protection violation, the Administrator provided only one training on data protection regulations for the employees in its organization, which took place 17 months before the date on which a successful attack on its IT infrastructure occurred. Attributing a certain rationality to the actions of the Administrator, which were presumably partly a result of his observations, based on which he considered that " (...) [f]rom a relatively small production plant, X has developed into a company employing a larger number of people, requiring a larger hardware base, professionalizing certain departments within the company structure (...)", it is impossible to assume that the educational initiatives undertaken by the Administrator were anything other than those aimed at ultimately raising the level of security of personal data processing operations and properly fulfilling the obligations imposed on him by data protection regulations. Thus, it can be concluded that he recognized – although no risk analysis in this regard was conducted by the Administrator – the connection between the technical and organizational measures implemented in his organization in the form of training for personnel to ensure an adequate level of security for personal data processing processes. Nevertheless, for unknown reasons, after June 30, 2018, the Administrator ceased any initiatives within his organization concerning data protection issues, only to briefly return to the desired practice on May 20, 2020, and then definitively abandon it, believing that " (...) the previously conducted [trainings on the aforementioned dates – added by the author] resulted in an increase in the awareness of the Administrator's employees in the area of personal data protection." Considering that before the occurrence of the aforementioned personal data breach, the Administrator conducted only one training session on personal data protection regulations for the employees in his organization, the agenda of which did not even cover issues related to the safe navigation of his staff on the Internet. Therefore, it is difficult to consider credible the declaration made in the mentioned letter dated February 16, 2021, stating that "(...) [e]mployees were aware that it is not permissible to independently configure the settings of hardware or software." Hypothetically assuming that such an organizational measure was indeed implemented in the Administrator's organization – which is not supported by the evidence he cited – it does not necessarily equate to the employees having knowledge of how they can actually protect themselves against cyber threats.

Furthermore, since the Administrator identified the vulnerability of the personal data protection system operating within his structure in the form of the "human factor," he should have been even more motivated to eliminate this "security gap," especially since at the time of the occurrence of the personal

data breach, he could not yet demonstrate the implemented mechanisms that would allow for effective oversight of the ways and purposes for which members of the staff used company equipment (the “(...) implementation of which (...) assigned users to roles corresponding to their positions, and then restricted their access to other resources. (...)”, as one of the security measures mitigating the risk of a recurrence of the personal data breach, the Administrator only indicated in a letter dated April 10, 2020). In light of the above, it should be emphasized that the Administrator's conduct of only one training session for the employees in his organization prior to the occurrence of the personal data breach cannot be considered as the implementation of a measure that effectively reduces the risk of a ransomware attack. This is not only due to the fact that the Administrator referred only to general principles of applying the provisions of Regulation 2016/679 in it. The explanations provided by the Administrator in the cited form also clearly indicate that this training took place on June 30, 2018, which means it occurred 17 months before the attack using the malware “M.” on November 25, 2019.

In this light, it cannot be stated that the organizational measure applied by the Administrator sufficiently shaped the awareness of those obligated to protect personal data and to apply procedures defining the security measures for that data. In striving to reduce the risk associated with a ransomware attack, the Administrator should have ensured that the training conducted on June 30, 2019, allowed its participants not only to acquire at least a basic level of necessary knowledge regarding the types of cyber threats and appropriate prevention techniques but also to initiate further educational sessions to consolidate the acquired skills. In this context, an adequate security measure, and thus a precise response to the risks associated with the processes of personal data processing related to ransomware, should be considered an organization of training for all individuals involved in these processes, which – alongside appropriate topics – would be characterized by a certain cyclicity. The omission of any of the highlighted elements will result in the training not fulfilling its role, the consequence of which may be – as in this case – a breach of personal data protection. In conclusion, conducting only one training session prior to the occurrence of the personal data breach, in addition to being described above, resulted in the organizational security measure applied by the Administrator not contributing to the reduction of the risk of the occurrence of the personal data breach, which determines the impossibility of demonstrating compliance with the requirements set out in Regulation 2016/679 regarding ensuring an adequate level of protection for personal data processing processes commensurate with the risk and, consequently, a breach of the accountability principle (Article 5(2) of Regulation 2016/679).

I.4. Software used for processing personal data. The analysis of the evidence collected in this case unequivocally indicates that no actions were taken to ensure the most up-to-date versions of the software being used. The Administrator did undertake appropriate actions in this regard in the form of, among others, “(...) updating operating systems to the latest available versions, changing (...) to (...); (...)”, but only after the occurrence of the personal data breach, thus allowing the data to be processed using outdated IT systems before its occurrence, and therefore systems that do not guarantee an appropriate level of security. There is no doubt that the circumstance cited by the Administrator in the document dated February 16, 2021, that “(...) a new server with licensed software was acquired in June 2018.” could not positively influence the objectively sustained “(...) elevated level of risk since October 2010 (...)”. As he indicated in an earlier letter dated April 10, 2020, “(...) actions aimed at strengthening the security of processed personal data (...)”, as a consequence of which, among other things: “(...) users were assigned to roles corresponding to their positions, a then their access to other resources was restricted (...)”; including “(...) the revocation of administrative rights from workstation users (...)”, “(...) the removal of users' ability to control antivirus software (...)”, and there was also the elimination of rights allowing “(...) to control the antivirus (...)”, so that “(...) the antivirus protection (...)” could “(...) be disabled only by the IT team (...)”, was effectively implemented by the Administrator only in the wake of the data protection breach in question. The use by workstation users of “(...) the licensed antivirus program A. (...)” could not in this case constitute fulfillment by the Administrator of the obligations imposed on him under Article 5(1)(f), Article 24(1), Article 25(1), and Article 32(1) of Regulation 2016/679, since these individuals had, during the period in which the data protection breach occurred, unrestricted access to interfere with the operation

of that software. As clearly demonstrated by the outcome of the proceedings initiated to determine the causes of the data protection breach in question, it was directly caused by “(...) the disabling of the licensed antivirus program A by one of the employees (...)”, as a result of which foreign processes were initiated on the server “(...) and the encryption process was started.” In this light, it should be noted that the events of November 25, 2019, could have been avoided by the Administrator if he had not only taken care to update the operating systems he used to the latest available and stable versions in a timely manner but also promptly revoked the rights of workstation users that allowed interference with the operation of system A., which, depending on the version used, combined the functions of a firewall and antivirus software, and thus was key software from the perspective of protecting the systems used in the processes of personal data processing, and above all exercised regular supervision over the ways in which business resources were utilized.

Thus, the argument presented by the Administrator in the letter of February 16, 2021, according to which “(...) [a]ccess to computers is protected by passwords. Access to the computer password is held solely by the staff member directly using the specific equipment. Specialized entities providing IT services ensure the integrity and security of the computer system and the information contained therein. In the event of leaving the workstation and temporary inactivity of the computer system, a screensaver is automatically activated, which can only be deactivated by entering the appropriate password. (...)”, does not withstand scrutiny when compared to the circumstances disclosed in this particular case, based on which it must be unequivocally concluded that the technical measures implemented by the Administrator did not continuously ensure an appropriate level of security for the data processed through the information systems he used, since the data protection breach did indeed occur.

In conclusion, it should be noted that having even the most technically advanced solutions, which in light of the explanations provided by the Administrator on April 10, 2020, did not occur (the Administrator indicated that as part of the remedial actions following the occurrence of the data protection breach, he made “(...) changes to the version of the antivirus software to ensure fuller protection ((...)) (...)”, thereby admitting that the previously used solution did not constitute a sufficient security measure for the processes of personal data processing), will not ensure a continuous appropriate level of security for the data processed through these information systems if the administrator not only does not take care to carry out periodic updates and optimize their configuration but also does not limit the rights of end users and – equally importantly – does not supervise their actions.

The findings made so far do not provide a basis for stating that the technical and organizational measures employed by the Administrator to ensure the security of personal data processing were adequate to the state of technical knowledge, the costs of implementation, and the nature, scope, context, and purposes of processing. Furthermore, these measures – in the opinion of the President of the UODO – were not adequately reviewed and updated, which consequently did not ensure effective implementation of data protection principles.

I.5. Lack of the Administrator's ability to quickly restore the availability of personal data in the context of the absence of regular testing, measuring, and evaluating the effectiveness of technical and organizational measures. The analysis of the evidence gathered in this case clearly reveals the Administrator's sluggishness in efforts aimed at fulfilling the obligations specified in Article 32(1)(c) and (d) of Regulation 2016/679, related to the ability to quickly restore the availability of personal data and access to it in the event of a physical or technical incident and regular testing of backup copies created. It should be noted that the Administrator regained access to the data only after a lapse of 4 days from their encryption. This circumstance thus provides grounds for the thesis that – due to the Administrator's failure to implement appropriate procedures for data recovery from backup copies in the event of a data protection breach – he was deprived of a real ability to quickly restore temporarily lost data.

Additional justification for the assumption adopted in the above form by the supervisory authority should

constituting a circumstance of the Administrator's failure to provide explanations – as requested by the President of the UODO in a letter dated July 1, 2021 – regarding the description of the procedures he employed for creating, storing, and testing backup copies prior to the occurrence of the data protection breach in question. Although he addressed the aforementioned issue in a letter dated August 16, 2021, the explanations provided by the Administrator only cover the period after November 25, 2019, which only strengthens the argument related to the lack of implementation by the Administrator of appropriate procedures for data recovery from backup copies prior to the mentioned date and obviously negates his ability to quickly restore the availability of personal data. As a consequence of this negligence, the restoration of personal data was only possible after 4 days from their encryption, which the Administrator could not have anticipated earlier, as the disclosed factual state of this case also lacks evidence that attempts to measure and assess the ability to quickly restore the availability of personal data were made by him at all. In this light, the Administrator's violation of the obligation specified in Article 32(1)(c) of Regulation 2016/679 should therefore not raise any doubts.

The Administrator's failure to meet the requirement of having the ability to quickly restore the availability of personal data and access to it in the event of a physical or technical incident fits into a broader context of the improper implementation by the Administrator of the obligation provided for in Article 32(1)(d) of Regulation 2016/679. By refraining from conducting regular testing, measuring, and assessing the effectiveness of the technical and organizational measures applied to ensure the security of the data processing processes occurring within his structure, the Administrator could not demonstrate knowledge regarding solutions related to network segmentation prior to the date of the data protection breach in question. Meanwhile, the implementation of such measures in the form cited by the Administrator in the letter dated April 10, 2020, i.e., "(...) the introduction of network segments and their separation through firewall rules, the establishment of a guest network (...)," only after the occurrence of the ransomware attack could – if not prevent – at least significantly limit the extent of negative consequences for individuals related to the 4-day unavailability of their personal data. In this context, it is also reasonable to accuse the Administrator of being unable to continuously ensure the confidentiality, integrity, availability, and resilience of processing systems and services (Article 32(1)(b) of Regulation 2016/679).

I.6. Order to adapt processing operations to the provisions of Regulation 2016/679. It should be noted that it was only the occurrence of the data protection breach on November 25, 2019, that prompted the Administrator to implement technical security measures, the description of which has been cited on pages 7 and 8 of the justification and in point 1 of the letter dated August 16, 2021, consisting of changing the logical topology of his IT structure and establishing a backup policy. However, it should be noted that the Administrator did not present any evidence unequivocally substantiating the fact of implementing the above-described technical security measures, taking into account the risk associated with the possibility of breaching the security of the IT system used by the Administrator in the processes of personal data processing and subsequently encrypting them.

Thus, he is unable to demonstrate in an indisputable manner that these measures constitute not an arbitrary, but indeed an adequate response to the existing risk associated with the possibility of re-losing the availability of the personal data processed by him. Moreover, the detachment of the implemented technical measures in the described form from risk analysis, coupled with the lack of evidence of their periodic evaluations by the Administrator, again raises questions about his ability to demonstrate continuous assurance of confidentiality, integrity, availability, and resilience of processing systems and services. Consequently, the argument outlined above remains valid, along with the related accusation of the Administrator's failure to adhere to the accountability principle specified in Article 5(2) of Regulation 2016/679.

In light of the above, the President of the UODO could not act otherwise than to issue to the Administrator – in accordance with the provisions of Article 58(2)(d) of Regulation 2016/679 – an order to adapt processing operations to the provisions of Regulation 2016/679, by conducting a risk analysis that considers threats related to the installation of malware interfering with the availability of personal data, and then implementing, based on the conducted risk analysis, adequate solutions to fully secure

the servers used by the Administrator in the processes of personal data processing and implementing appropriate technical and organizational measures to ensure regular testing, measuring, and assessing the ability to quickly restore the availability of personal data and access to it in the event of a physical or technical incident.

II. Responsibility of the Data Processor. There is no doubt that a comprehensive consideration of all the evidence collected in this case would not be possible without the supervisory authority taking into account the circumstances cited by the Administrator in the letter dated April 10, 2020, in which the occurrence of the data protection breach was to be "(...) caused by a double..." human factor - [faulty behavior – ed. note] of the employees of the Administrator and the company that had previously provided IT services to the Administrator." In the course of the explanations provided, the Administrator indicated that "(...) the previous company (whose services the Administrator was dissatisfied with due to the lack of timely provision of maintenance services and security system audits) was replaced at the turn of September and October 2019 by company Y s.c." This new entity, in the Administrator's assessment (meanwhile, the evidence gathered in this case clearly indicates that the civil partnership Y and the Administrator were connected by an agreement made on May 24, 2018 "...", and informal cooperation lasted "(...) at least since 2010 (...)", "(...) was supposed to take over the security of the IT systems at the Administrator, conduct a security audit, and prepare a report in this regard (...)". As the Administrator further communicated, "(...) it turned out that this entity also failed to fulfill its obligations and misled the Administrator, because (which the Administrator was not aware of at the time), at the same time this new entity was performing another very large order for a third party, which resulted in an incident occurring in November 2019."

Undoubtedly, the credibility of the facts presented in the above form, indicating – in the opinion of the Administrator – the shared responsibility of the partners of Y s.c., i.e. Ms. CD, Mr. EF, and Mr. GH, for the occurrence of the aforementioned violation of personal data protection, must be considered – in light of the lack of a written agreement for the provision of services to be performed by the partners of Y s.c. for the Administrator "(...) at least since 2010 (...)" – in relation to the disclosed content of the agreement made on May 24, 2018 "...".

It should therefore be noted that § (...) item (...) of the aforementioned document indicates that the entrustment by the Administrator of the processing of personal data on his behalf and for his benefit to the partners of Y s.c. took place for the purpose of executing the agreement regarding the operation, exploitation, and maintenance of system d. in the Administrator's enterprise and duly fulfilling obligations towards state authorities empowered by law, which is not equivalent to exercising supervision over the entire IT infrastructure within the structure of the Administrator, a circumstance that the Data Processor also referred to in a letter dated July 8, 2022.

Of course, there remains the consideration of the eventuality in which, alongside the main relationship of entrusting the processing of personal data, Y s.c. would be providing IT services at the request of the Administrator. However, this hypothesis is not confirmed by the gathered evidence, in which there is no record of any trace of even informal initiatives on the part of the Administrator aimed at obtaining assistance from the Data Processor in fulfilling the obligations defined in Articles 32-36 of Regulation 2016/679. It is also difficult to rationally assume that the Data Processor would act outside the mandate defined in Article 28(3)(a) of Regulation 2016/679, arising solely from the documented instruction of the Administrator. For the aforementioned reasons, it is also impossible to accept the truth of the Administrator's statement regarding the existence of an obligation on the part of the Data Processor to conduct a security audit and prepare a report in this regard, since the aforementioned "(...)" did not require this from him in any way.

Finally, it is impossible not to notice that the direct cause of the security incident on November 25, 2019, which led to the violation of personal data protection processed in the Administrator's information systems, was the infection of one of the employee computers "(...) (...) (...)", "(...) due to (probably accidental) disabling of the licensed antivirus program A. by one of the Administrator's employees," for which the Administrator is responsible. He allowed a situation in which granting end users permissions inconsistent with their job classification enabled them to interfere with the operation

of the antivirus software, of which the Administrator could not be aware, since – as demonstrated in the earlier pages of the justification of this decision – at the time of the occurrence of the aforementioned violation of personal data protection, he did not possess the technical instruments allowing for effective supervision over the ways in which his employees used company resources.

The issue of the lack of cyber security awareness training for employees in the Administrator's organization, which, if conducted by him, would constitute the implementation of organizational security measures adequate to the risk associated with personal data processing, for which the Administrator is also solely responsible, is also significant. The use by the perpetrators of the vulnerability of "(...) server B., which had not been updated for a long time" is yet another manifestation of the neglect on the part of the Administrator, who, as the host of personal data processing processes, did not adequately ensure the ongoing update of the software, for which the partners of Y s.c. are not responsible, since under the provisions of their agreement with the Administrator "(...)" dated May 24, 2018, confirmed by the content of their consistent statements dated July 8, 2022, they were responsible not for the operation and maintenance – remaining within the structure of the Administrator – of server B., but for actions "(...) in the area of operation, exploitation, and maintenance of system d. in the Administrator's enterprise," which – importantly – did not include the right to interfere with the technical security measures implemented by the Administrator.

It should also be noted that, in the opinion of the authority supervision circumstances, the factual circumstances of the case do not provide grounds to conclude that the maintenance and security of the IT infrastructure of the server "(...) >>(...) << [on which the subject data protection breach occurred – ed. note] (...)", on which the system d. was installed, did not – contrary to its own claims – belong to the Administrator. This is implicitly confirmed by the fact that it was the Administrator who, on its own initiative, undertook a series of actions after November 25, 2019 – in the area of technical security – aimed at eliminating the effects of the subject data protection breach and preventing similar occurrences in the future (in particular, it replaced the outdated system (...) with (...)).

In light of the aforementioned arguments, the fact that the Data Processor was entrusted with personal data for processing in system d., in the scope of which – incidentally – no lack of adequate risk-mitigating measures regarding the occurrence of a data protection breach was found (unlike the operation of the server software on which program d. was installed), excludes – in the opinion of the President of UODO – the possibility of attributing responsibility to the Data Processor for the failure to implement organizational and technical security measures within the entrusted processing process. For the above reasons, it is also impossible to attempt to shape joint liability of the Data Processor for the Administrator's demonstrated negligence regarding the organizational and technical security measures implemented by it.

Nevertheless, there are no grounds to assume joint liability of Ms. CD, Mr. EF, and Mr. GH for the demonstrated negligence towards the Administrator in the selection of ineffective security measures for the IT system used for processing personal data and the lack of appropriate testing, measuring, and assessing the effectiveness of technical and organizational measures intended to ensure the security of the processed personal data in the IT systems covered by the breach, particularly regarding vulnerabilities, errors, and their possible consequences for these systems, as well as the actions taken to minimize the risk of their occurrence. This does not in any way diminish the necessity of seeking the liability of the partners of Y s.c. for failing to assist the Administrator in fulfilling its obligation to implement adequate technical and organizational measures ensuring the security of personal data processing, i.e., for violating Article 28(3)(f) in connection with Article 32(1) and (2) of Regulation 2016/679.

The validity of such an accusation against the Data Processor should not raise any doubts, as the established evidence in this case clearly indicates (as both the Data Processor and the Administrator informed in their letters dated September 29, 2023, and October 3, 2023, respectively) that "(...) the system >>d.<< was installed on the server >>(...) << [on which the subject data protection breach occurred – ed. note], using software E.", and thus – as has already been demonstrated in this decision

– the IT architecture had a number of commonly known security flaws, of which the partners of Y s.c. must have been aware, as they not only had “(...) many years of experience in implementing systems based on the (...) platform and adapting them to the individual needs of the client (...)”, or “(...) the most experienced implementation team in Poland (...)”, but also the status of “(...) (...)”. Unfortunately, despite the undoubtedly possessed competencies and knowledge of the aforementioned individuals regarding the fact that “(...) [n] the server using software E. had the server (...) with a database that was used by system d. The installation of the client application d. was performed on the users' computers”, they refrained from providing the Administrator with information about the vulnerabilities present in software E.

In this context, it is all the more futile to seek justification for the partners of Y s.c. not undertaking any initiatives over the years related even to attempting to communicate to the Administrator the necessity of updating the operating system to the latest possible version or even implementing newer solutions, which would thus constitute a more adequate response to the inherent risks associated with the processes of personal data processing (e.g., in the form of implementing system B., which ultimately occurred in the Administrator's structure only after the occurrence of the subject data protection breach). There is no doubt that the use of this software, which incidentally had its global premiere (...), to service “(...) the server (...) with a database that was used by system d.”, would significantly mitigate the risk of materializing such an attack on the Administrator's IT infrastructure, which occurred precisely on November 25, 2019. For the reasons outlined above, the occurrence of the subject data protection breach was thus significantly contributed to by the actions of the partners of Y s.c., characterized by gross negligence, who – as established – provided IT support services to the Administrator concerning system d. In the normal course of activities and in accordance with a risk-based approach, they should have, especially as IT professionals, anticipated based on the conducted risk analysis the consequences that relying on solutions that do not provide sufficient assurance of security could have for the safety of the personal data entrusted to them.

The above argumentation is not diminished by the fact that the partners of Y s.c. could not independently and in

****Regarding the services provided to the Administrator by the IT service provider, to remove vulnerabilities in the software of the server on which system d is installed. However, being aware of their existence, they did not notify the Administrator of this fact, which excludes the possibility of accepting that the Data Processor fulfilled the obligation to provide the Administrator with "assistance" taking into account "the information available to it," which constitutes a violation by the partners of Y s.c. addressed solely to the Data Processor of the obligations specified in Article 28(3)(f) of Regulation 2016/679. The failure of the Data Processor to comply with the obligations imposed on it in this regard establishes, under the indicated provision of Regulation 2016/679, its separate liability of a public law nature, thus remaining detached from its contractual obligations and constituting an independent basis for the supervisory authority to impose sanctions, in accordance with Article 83(4)(a) of that Regulation.****

****III. Relationship between the Administrator and the Data Processor.**** However, the previous findings do not exclude the necessity of a more detailed examination of the accusation raised by the Administrator against the aforementioned Data Processor regarding its improper fulfillment of obligations related to ensuring “(...) the security of IT systems at the Administrator (...)”, conducting security audits, and preparing appropriate reports based on them. As follows from Article 28(1) of Regulation 2016/679, if processing is to be carried out on behalf of the administrator, it may only use the services of such data processors that provide sufficient guarantees to implement appropriate technical and organizational measures so that the processing meets the requirements of Regulation 2016/679 and protects the rights of the data subjects. The obligation to ensure the implementation of this principle is served by the requirement introduced in Article 28(3) of Regulation 2016/679 to conclude an agreement between the administrator and the data processor specifying the subject and duration of the processing, the nature and purpose of the processing, the type of personal data, and the categories of data subjects, as well as the obligations and rights of the administrator, which

agreement includes, in particular, the elements indicated in points (a) to (h) of that provision.

In the examined factual state, the agreement between the Administrator and the Data Processor “(...)” dated May 24, 2018, did indeed contain all the elements specified in the aforementioned provision; however, based on the explanations provided by the aforementioned entities, it is impossible to determine whether the actions taken by the partners of Y s.c. “(...) to fulfill the agreement regarding the management, operation, and maintenance of system d. in the Administrator's enterprise (...)” presented by the Data Processor in the letter dated July 8, 2022, were carried out according to predetermined principles ensuring the security of personal data. Apart from the general statements contained in § (...) of the referenced document, under which the Data Processor undertook, among other things, to secure the entrusted processes of personal data processing “(...) by applying appropriate technical and organizational measures ensuring an adequate level of security corresponding to the risk associated with the processing of personal data referred to in Article 32 of the Regulation [Regulation 2016/679 – ed. note],” the technical and organizational measures intended to ensure this security were not specified either in the general regulations implemented by the Administrator or in the relevant agreement concluded with the Data Processor.

Based on the outlined factual circumstances, a picture emerges in which the means and methods of implementing the solutions “(...) regarding the management, operation, and maintenance of system d. in the Administrator's enterprise (...)” were indeed decided by the partners of Y s.c. The discretion of the Data Processor in choosing the solutions used should not be surprising, since the Administrator, who should have positioned himself as the host of the data processing processes carried out on his behalf and for his benefit, did not outline precise frameworks for cooperation with the Data Processor, and the lack of implemented procedures regarding the control of the correctness of actions taken by the Data Processor only deepened this state, characterized by a lack of appropriate insight into the actions of the aforementioned entity on the part of the Administrator.

Given that the Data Processor was left with a kind of discretionary authority to decide on the methods of performing actions “(...) regarding the management, operation, and maintenance of system d. in the Administrator's enterprise (...)”, it is necessary to further analyze whether such action by the Administrator could have stemmed from a justified certainty regarding the competence of the Data Processor. In this case, the Administrator indicated that the cooperation with the Data Processor began long before the provisions of Regulation 2016/679 came into force, i.e., it lasted “(...) since at least 2010 (...)”. From the explanations provided by the Administrator, in which he stated that based on the information available on the Data Processor's website, he established that this entity has been operating “(...) in the market since 2004, has a large staff and a significant portfolio of clients (...)”, it does not appear that the verification of the competence of the partners of Y s.c. bore the hallmarks of a formalized process. Nevertheless, in the opinion of the Administrator, he exercised “(...) due diligence in selecting the entity providing IT support for the enterprise,” because “(...) [the] conclusion of the agreement with this entity was therefore...”

preceded by an analysis of their professional experience in the area of providing IT solutions.”

In response to the aforementioned explanations of the Administrator, it should be noted that under the previous legal framework defined by the Personal Data Protection Act (uodo), different requirements were established for the data processor, while different ones have been in effect since May 25, 2018, i.e., from the moment the Regulation 2016/679 came into force. Therefore, the previously positively assessed cooperation can only serve as a starting point in verifying whether the data processor provides sufficient guarantees for the implementation of appropriate technical and organizational measures to ensure that the processing meets the requirements of Regulation 2016/679 and, above all, protects the rights of the data subjects. The requirement specified in Article 28(1) of Regulation 2016/679 is binding on every data controller who, in the course of their activities, uses the resources or services of a data processor when processing personal data. It should be emphasized that the obligation to conduct such an assessment is not waived by the fact of long-term cooperation and the use of services of a given data processor prior to May 25, 2018, i.e., before the commencement of the application of the provisions of Regulation 2016/679. The Administrator did not conduct such

verification, relying solely on the positive assessment of the Data Processor, which was the result of previous cooperation established long before the commencement of the application of the provisions of Regulation 2016/679. The failure to conduct this assessment by the Administrator is tantamount to a violation of the obligation specified in Article 28(1) of Regulation 2016/679.

It should be noted that merely signing a data processing agreement without conducting an appropriate assessment of the data processor cannot be perceived through the lens of due performance by the Administrator of the obligation to conduct a verification procedure of the Data Processor regarding compliance with the requirements of Regulation 2016/679. Long-term cooperation between the parties, unsupported by periodic, systematic audits or inspections, does not guarantee that the data processor will correctly fulfill the tasks required by law and arising from the concluded data processing agreement. Just as in the present case, where the allegation made by the Administrator against the partners of Y s.c., concerning the non-performance or improper performance of obligations by this entity, only arose in the letter dated April 10, 2020, raising – contrary to the Administrator's intention – questions about the earlier performance of compliance checks by him regarding the processes of personal data processing carried out on his behalf and for his benefit, consequently undermining the validity of the theses formulated by the Administrator. Moreover, they become even more incomprehensible when compared to the provisions established by the parties in the “(...)” dated May 24, 2018, which stipulate in § (...) the right of the Administrator to conduct checks to determine “(...) whether the measures applied by the Data Processor in the processing and securing of entrusted personal data meet the provisions of the agreement,” where the circumstances of exercising the mentioned right – in light of the evidence gathered during these proceedings – the Administrator is unable to effectively demonstrate in relation to the entire duration of the contract with the Data Processor. Meanwhile, the control mechanisms implemented by those responsible for assessing the adequacy of guarantees provided by the data processor to the administrators constitute a fundamental tool for verifying the data processor, particularly in terms of the technical and organizational measures implemented by the processor to ensure an appropriate level of protection for personal data processing.

The issue of criteria for assessing the data processor was also the subject of considerations by the European Data Protection Board (EDPB). As indicated in the “Guidelines 07/2020 on the concepts of controller and processor contained in the GDPR,” hereinafter referred to as Guidelines 07/2020, referring to the content of Article 28(1) and Recital 81 of Regulation 2016/679, (quote): “The Administrator is (...) responsible for assessing the adequacy of the guarantees provided by the data processor and should be able to demonstrate that they have seriously considered all elements provided for in the GDPR. The guarantees ‘provided’ by the data processor are those that the data processor can satisfactorily demonstrate to the administrator, as these are the only guarantees that the administrator can effectively take into account when assessing compliance with their obligations. This will often require the exchange of appropriate documentation (e.g., privacy policies, terms of service, processing activity registers, document management policies, information security policies, reports from external data protection audits, recognized international certifications such as ISO 27000 standards). The administrator's assessment of whether the guarantees are sufficient is a form of risk assessment that largely depends on the type of processing entrusted to the data processor and must be conducted individually for each case, taking into account the nature, scope, context, and purposes of the processing, as well as the risks to the rights and freedoms of natural persons. (...) The Administrator should take into account the following elements (...) to assess whether the guarantees are sufficient: expertise (e.g., technical knowledge regarding security measures and data breaches); reliability of the data processor; resources of the data processor. The reputation of the data processor in the market may also be an important factor that administrators should consider. Furthermore, as an element enabling the demonstration...

sufficient guarantees can be utilized
compliance with the approved code of conduct
or certification mechanism. (...) The obligation
to use only the services of entities

processing data that "provide sufficient guarantees" as stated in Article 28(1) of the GDPR is a continuous obligation. It does not end at the moment of concluding a contract or other legal act by the controller and the processor.

The controller should rather verify the guarantees of the processor at appropriate intervals, including in appropriate cases through audits and inspections (...)».

Referring the above opinion of the EDPB to the circumstances of the disclosed factual state, it can be noted that the Controller, entrusting the partners Y s.c. with the processing of personal data of its employees, temporary workers, contractors, family members of employees, interns, trainees, and contractors, was guided by faith in the expert knowledge of the Processor "(...) in the area of providing and optimizing IT business solutions that increase the efficiency of the organization (...)". He trusted that it had "(...) many years of experience in implementing systems based on the platform (...) and adapting them to the individual needs of the client (...)” and that it is distinguished not only by "(...) the most experienced implementation team in Poland (...)", but also by the status of "(...) (...)". In light of the above-mentioned recommendations of the EDPB, the above beliefs held by the Controller regarding the Processor should, in the normal course of events, become a reason for him to conduct – even based on the exchange of relevant documentation – an element of a broader risk analysis study of adequacy, provided by the Processor guarantees of ensuring the level of protection of the entrusted data of the aforementioned categories of persons, which

in the disclosed circumstances of this case did not take place. In this context, it should therefore not be surprising to encounter a situation in which the actions taken by the partners of Y s.c. related to the operation and maintenance of system d., using outdated and thus not providing an adequate response to the objectively existing risk to the security of the processes of personal data processing contained in the database (...) of the server software "(...) (...) (...)", directly contributed to the occurrence on November 25, 2019, of the subject data breach. The identification of irregularities in the structure of the Controller related to the organization and management of the process of implementing new solutions in the IT infrastructure or making changes in it can take place even after considering the efforts made by the Processor after the mentioned date (vide: pages 14 and 15 of the justification of this decision).

IV. Joint Responsibility of the Controller and the

Processor for the omissions regarding the conduct of a risk analysis for the purposes of "(...) operation, exploitation, and maintenance of system d. (...)”, determining and applying adequate technical and organizational measures to ensure the security of the processing processes carried out using this software and verifying the effectiveness of the security measures of the Controller's IT infrastructure. Undoubtedly, the responsibility for applying appropriate, i.e., adequate to the existing risk, technical and organizational measures to ensure the security of processed personal data extends to all entities participating in the processes of personal data processing, and thus in this specific case to the Controller and the individuals who were partners of Y s.c. on November 25, 2019.

As a consequence of this assumption, it should be stated that both the Controller and the Processor should have verified whether the personal data was adequately secured against a possible ransomware attack. The lack of such verification and the failure to implement technical and organizational measures aimed at effectively securing personal data processed in system d., as using outdated server software on which the database containing personal data was hosted cannot be considered sufficient, significantly contributed to the occurrence of the subject data breach. Furthermore, the actions, the nature of which was recorded in the explanations submitted on April 10, 2020, and August 16, 2021, were taken only after the event of November 25, 2019, and aimed solely at minimizing the risk of a recurrence of the breach.

In light of the above findings, it should therefore be stated that the omissions on both the part of the Controller and the Processor regarding the conduct of a risk analysis for the purposes of "(...) operation, exploitation, and maintenance of system d. (...)”, determining and applying adequate technical and organizational measures to ensure the security of the processing processes carried out using this software and verifying the effectiveness of the security measures of the Controller's IT infrastructure, resulted in a violation by the aforementioned entities of Article 32(1) and (2) of Regulation 2016/679.

It should be noted that the findings made in this case do not provide grounds to conclude that the organizational measures applied by the Controller to ensure the security of personal data were adequate to the state of technical knowledge, costs of implementation, and the nature, scope, context, and purposes processing, which consequently did not ensure the effective implementation of personal data protection principles. As a result – in the opinion of the President of the UODO – the Administrator did not implement appropriate organizational measures to continuously ensure the security of personal

data processing in the IT system d., which in turn constitutes a violation of Article 32(1) and (2) of Regulation 2016/679. The mere conclusion of an agreement with the Processor on May 24, 2018, “(...)”, cannot be considered as the implementation of such a measure, as the Guidelines 07/2020 EROD clearly indicated that (quote): “Although the elements specified in Article 28 of the Regulation constitute its core content, the contract should serve as a means for the administrator and the processor to further clarify how to implement these essential elements through detailed instructions.” There is no doubt that the formulation of these detailed instructions should be attributed to the administrators, who determine, under Article 4(7) of Regulation 2016/679, the purposes and means of processing personal data, including in relation to processes carried out on their behalf and for their benefit by external entities.

Referring the above to the context of the case at hand, it should be indicated that the Administrator, due to the lack of procedures ensuring the security of processed data during changes made in the IT system d., in which this data is processed, and the lack of supervision over the Processor “(...) concerning the management, operation, and maintenance of the system d. in the Administrator's enterprise (...)” improperly fulfilled its role in implementing appropriate technical and organizational measures to ensure that processing was carried out in accordance with Regulation 2016/679 and to provide the necessary safeguards for processing, so as to meet the requirements of this act, thereby failing to comply with the obligations set forth in Articles 24(1) and 25(1) of Regulation 2016/679.

As a consequence of the above omissions, it must be stated that the principle of integrity and confidentiality expressed in Article 5(1)(f) of Regulation 2016/679 was violated by the Administrator. Furthermore, being unable to demonstrate that the processes of personal data processing occurring in its organization corresponded to an adequate level of security, the Administrator violated the principle of accountability referred to in Article 5(2) of Regulation 2016/679. Regardless of the above, as demonstrated in the earlier part of the justification of this decision, the causes of the occurrence of the aforementioned personal data breach should also be sought in processes directly related to the improper fulfillment of contractual obligations by the partners of Y s.c. “(...) concerning the management, operation, and maintenance of the system d. in the Administrator's enterprise (...)”. In this context, the attribution of co-responsibility to the aforementioned individuals for the materialization on November 25, 2019, of the risk associated with a ransomware attack on the Administrator's IT infrastructure is determined by the circumstance that, based on the agreement concluded on May 24, 2018, “(...)”, confirmed by their identical statements submitted to the President of the UODO on July 8, 2022, “(...) [t]he company Y was responsible for providing the database server, licenses, implementation, and maintenance work related to the system d.”. The logical consequence of the existence of the set of obligations of the Processor in this regard, resulting from the consistent statements of the partners of Y s.c. revealed during these proceedings, quote “(...) [o]n the server [...]” using the E. software, a server (...) with a database was installed, which was used by the system d.”, was their full awareness of the fact that the software of this server, i.e., B., had not been updated for a long time. Despite this, they knowingly allowed “(...) the server (...) with the database, which was used by the system d. (...)” to be hosted on a server operated by software E., which had numerous security flaws, where one of these vulnerabilities was successfully exploited by unidentified perpetrators to carry out a successful attack on November 25, 2019, and fully encrypt the database containing personal data.

Meanwhile, both the Administrator and the partners of Y s.c. acting on its behalf and for its benefit should have demonstrated the implementation of technical measures ensuring the security of personal data processed in the system d., which – as demonstrated – did not take place. The findings made during these proceedings thus provide grounds for a justified thesis that by refraining from implementing appropriate technical and organizational measures to ensure that processing was carried out in accordance with Regulation 2016/679 and to provide the necessary safeguards for processing, the Administrator did not adequately mitigate the inherent risk associated with personal data processing processes. The partners of Y s.c., on the other hand, despite their knowledge regarding the outdated and thus vulnerable server software used in the data processing processes

(which ultimately materialized), did nothing to counteract this state of affairs. This constitutes a failure on their part to meet the requirements set forth in Article 28(3)(f) in conjunction with Articles 32(1) and (2) of Regulation 2016/679, understood as the obligation to support the administrator in its efforts to implement adequate technical and organizational security measures for personal data processing that correspond to the existing risk. The above argumentation does not diminish, in light of the proven omissions on the part of

the position that the Administrator fulfilled its obligation to notify the data subjects in accordance with all the elements indicated in Article 34(2) of Regulation 2016/679.

VI. Conclusion. In light of the above findings, the President of the Personal Data Protection Office (UODO) concludes that the Administrator has committed violations of Article 28(1) and Article 34(2) of Regulation 2016/679. Consequently, the President of UODO is obliged to impose an administrative fine on the Administrator, taking into account the nature, gravity, and duration of the infringement, as well as any previous infringements, the degree of responsibility of the Administrator, any financial benefits gained or losses avoided, and the degree of cooperation with the supervisory authority.

The President of UODO, therefore, decides to impose an administrative fine on the Administrator in the amount of [insert amount] PLN, which is to be paid within 30 days from the date of delivery of this decision.

The Administrator has the right to appeal against this decision to the competent administrative court within 30 days from the date of its delivery.

This decision is final and binding.

[Signature]

President of the Personal Data Protection Office

[Date]

of the document formulated by the Administrator, according to which "the purpose of encrypting the data was not their theft." Considering the information provided by the Administrator in a letter dated March 5, 2020, stating that he "(...) does not possess data that unequivocally excludes the possibility of data being accessed by unauthorized third parties during the breach," the President of the UODO, guided by a high degree of caution, deemed it justified to conclude that there was a very high probability that the confidentiality of personal data processed by the Administrator may have been violated in this case. Undoubtedly, the failure of the Administrator to provide details regarding the conducted explanatory proceedings and their results in his previous explanations, particularly the lack of sufficient evidence to establish appropriate findings to genuinely determine the operation of the malicious software, reinforced the supervisory authority's conviction in this regard. At the same time, it should be noted that a comprehensive analysis of the documentation submitted by the Administrator in this matter shows that he has not yet provided convincing evidence to support his claims.

Consequently, the position expressed by the President of the UODO on March 13, 2020, regarding the justified suspicion of a potential violation of the confidentiality of personal data processed by the Administrator as a result of the ransomware attack on November 25, 2019, remains valid.

In light of the above reasoning, it is impossible to conclude that the Administrator, by notifying former and current employees (i.e., a total of "(...) approx. 200 (...) individuals) on March 21, 2020, about the "Personal Data Breach," did so while considering all the required elements under the provisions of Article 34(2) of Regulation 2016/679, to which he was obliged, identifying the high risk of the personal data breach that occurred on November 25, 2019 (the supervisory authority's conclusion is supported by the Administrator's issuance of a renewed notification on March 21, 2020, to the individuals concerned regarding the breach of their personal data), in accordance with Article 34(1) of Regulation 2016/679. Unable to unequivocally exclude that in this case there was a breach of confidentiality of a wide range of data concerning the aforementioned categories of individuals, the Administrator should have, adopting the perspective of protecting the interests of data subjects and demonstrating a high degree of caution, provided them with all legally required information. Meanwhile, the analysis of the content of the notification sent on March 21, 2020, to the individuals concerned shows that the

Administrator did indicate to both former and current employees certain possible consequences of the breach and remedial measures they could take to minimize the negative consequences of the data breach, which were listed on page 7 of the justification of this decision; however, in the opinion of the supervisory authority, these measures remain inadequate in relation to the risk arising from the breach in question. By not addressing all disclosed categories of data, particularly those whose unauthorized disclosure is associated with a high risk of violating the rights or freedoms of natural persons, i.e., the set of data including PESEL number, first name, and surname, they do not sufficiently mitigate its negative effects.

Regardless of the risk assessment conducted by the Administrator regarding the violation of the rights or freedoms of natural persons, the above argument is strengthened by considering that as a result of the personal data breach in question, the confidentiality of the PESEL number, which is an eleven-digit numerical symbol allowing not only for the unambiguous identification of natural persons but also containing their date of birth and gender designation, may have been compromised, thus providing information closely related to their privacy. Furthermore, it should also be taken into account that as a result of the data breach, there is a high probability that the confidentiality of this identification number, along with the first names and surnames of former and current employees of the Administrator, may have been lost to unidentified perpetrators of the attack on his IT infrastructure. After all, this very combination of personal data can be sufficient for "impersonating" the individual whose data is concerned and incurring financial obligations in their name and to their detriment (see:

<https://www.bik.pl/poradnik-bik/wyludzenie-kredytu-tak-dzialaja-oszusci> – where a case is described in which: "Only the first name, surname, and PESEL number were enough for the fraudsters to obtain several loans totaling tens of thousands of zlotys. Nothing else matched: neither the ID number nor the address of residence," accessed on September 2, 2024). It cannot be overlooked that the data breach in question involved an even broader catalog of personal data of former and current employees of the Administrator, including – according to his declaration – categories such as: "(...) parents' names, date of birth, bank account number, address of residence or stay, (...), email, series and number of the ID card, phone number," which, combined with the criminal actions of individuals who potentially obtained the aforementioned information concerning the Administrator's staff, only raises the potential severity of the risk of violating the rights or freedoms of the data subjects.

The issue of breaches of confidentiality of national identification numbers and the resulting obligations of administrators towards both the supervisory authority and the individuals concerned has also been addressed by the EROD in the "Guidelines 01/2021 on examples regarding the reporting of personal data breaches," adopted on December 14, 2021.

2.0 (hereinafter referred to as EROD Guidelines 01/2021). Discussing in the cited document the case of "the accidental mailing of highly confidential personal data," in which a social security number was disclosed, which is, by the way, equivalent to the PESEL number used in Poland, EROD unequivocally concluded that the disclosure of data concerning: name and surname, email address, postal address, and social security number indicates a high risk of infringement of the rights or freedoms of natural persons ("the involvement of their [the affected persons'] social security number, as well as other, more basic personal data, further increases the risk that can be classified as high"), which consequently implies the necessity to notify the supervisory authority and inform the individuals whose data is concerned about the breach. A similar position has also been expressed multiple times by the Provincial Administrative Court in Warsaw (see: judgment of July 1, 2022, case file II SA/Wa 4143/21, judgment of September 22, 2021, case file II SA/Wa 791/21, judgment of November 15, 2022, case file II SA/Wa 546/22, judgment of June 21, 2023, case file II SA/Wa 150/23, and judgment of November 6, 2023, case file II SA/Wa 996/23), as well as by the Supreme Administrative Court in the judgment of December 6, 2023, case file III OSK 2931/21.

Therefore, relating the aforementioned argumentation to the presented factual state, it should be emphasized that in the case of any doubts regarding the fulfillment of obligations by administrators – including situations where there has been a breach of personal data protection – one should primarily, referring to the purposive interpretation of Regulation 2016/679, take into account the rule expressed

in Article 1(2) of this legal act, according to which the primary objective of the regulations contained therein is always the protection of the fundamental rights and freedoms of natural persons, in particular their right to the protection of personal data. Thus, in an attempt to fulfill the above-mentioned postulate, the Administrator should have conducted a risk analysis following the occurrence of the relevant personal data breach concerning the legally protected values related to those individuals.

He was therefore obliged to consider, guided by – according to the guidelines in force at the time of the occurrence of the relevant personal data breach – the Guidelines of the Article 29 Working Party "on notifying personal data breaches in accordance with Regulation 2016/679," hereinafter referred to as "WP250 Guidelines" (currently, the EROD Guidelines 9/2022 "on notifying personal data breaches in accordance with GDPR" are applied, hereinafter referred to as "Guidelines 9/2022") – the criteria of the type of personal data breach, the nature, sensitivity, and amount of personal data, the ease of identifying natural persons, the severity of the consequences for the individuals concerned due to this breach, the number of individuals whose data was subject to the relevant breach, specific circumstances of the personal data breach, including in accordance with recitals 75 and 76 of the preamble to Regulation 2017/679, the severity of potential effects and the likelihood of their occurrence. A high level of any of these factors affects the overall assessment, on which the fulfillment of the obligations specified in Article 33(1) and Article 34(1) of Regulation 2016/679 depends.

Considering that due to the scope of potentially disclosed personal data in the analyzed case, there was – as demonstrated above – a possibility of significant negative consequences materializing for former and current employees of the Administrator, the weight of the potential impact on the rights or freedoms of a natural person should be regarded as high. At the same time, the probability of high risk occurring as a result of the relevant breach is not small and has not been eliminated. Thus, it should be stated that in connection with the relevant breach, there was a high risk of infringement of the rights or freedoms of the individuals whose data is concerned, which consequently determines, among other things, the obligation to notify former and current employees of the Administrator about the breach of their personal data protection, in accordance with Article 34(1) of Regulation 2016/679, taking into account all elements indicated in Article 34(2) of Regulation 2016/679 (the condition of high risk does not occur in the case of "(...) customers who have made a purchase at least once (...)” in the Administrator's enterprise due to the scope of information concerning these individuals, i.e., name, surname, bank account number, residential address, business address, NIP, email, phone number, data concerning placed orders).

As an exemplification of the opposite state to that postulated by the EU legislator, one should indicate the notification sent by the Administrator on March 21, 2020, to the individuals whose data is concerned, in which the Administrator did not list all foreseeable consequences of the occurrence of the personal data breach and did not formulate corresponding recommendations regarding actions that the individuals whose data is concerned could take to fully secure their privacy, thereby depriving them of the possibility of effectively countering potential damages. The above constitutes a violation by the Administrator of Article 34(2) of Regulation 2016/679, which aims not only to ensure the most effective protection of the fundamental rights or freedoms of data subjects but also to implement the principle of transparency, which arises from Article 5(1)(a) of Regulation 2016/679 (see Chomiczewski Witold (in:) GDPR. General Regulation on Data Protection. Commentary. ed. E. Bielak - Jomaa, D. Lubasz, Warsaw 2018).

Proper fulfillment of the obligation specified in Article 34 of Regulation 2016/679 is to ensure that individuals whose data is concerned receive quick and transparent information.

****On the Violation of the Protection of Their Personal Data Along with a Description of Possible Consequences of the Violation of Personal Data Protection and Measures They May Take to Minimize Its Potential Negative Effects, Which – Considering Both the Scope of the Categories of Personal Data Covered by the Relevant Violation of Personal Data Protection and the Context of Processing in Which It Occurred – May Prove to Be Significant, e.g., by Incurring Financial Obligations to the Detriment of Former and Current Employees of the Administrator.****

A perfect example of the materialization of the aforementioned risk is contained in the report infoDOK –

prepared as part of the social Information Campaign of the RESTRICTED DOCUMENTS System, organized by the Polish Bank Association and certain banks, under the patronage of the Ministry of Interior and Administration (MSWiA) and in cooperation, among others, with the Police and the Consumer Federation – (see: <https://www.zbp.pl/raporty-i-publikacje/raporty-cykliczne/raport-infodok>). It follows from this report that in the fourth quarter of 2019, during the time of the occurrence of the relevant violation of personal data protection, there were 1,607 attempts to defraud loans and credits for a total amount of PLN 58.4 million, which means that every day there were attempts to commit theft using someone else's personal data totaling PLN 642 thousand, which, in turn, given the demonstrated negligence on the part of the Administrator in providing the individuals concerned with an inadequate communication regarding all potential consequences of the relevant violation of personal data as well as recommendations to minimize the likelihood of their update, undoubtedly has significant importance. For comparison, in the fourth quarter of 2020, there were attempts to defraud 1,943 loans for a total amount of PLN 67.3 million, while in the fourth quarter of 2021, there were 2,075 attempts to defraud loans for a total amount of PLN 91.3 million, which constitutes an excellent illustration of the disturbing upward trend in the risk of using someone else's personal data for criminal acts. Furthermore, as follows from the case law, judgments in cases of loan fraud are not uncommon and have been issued by Polish courts in similar cases for a long time – for confirmation: the judgment of the District Court in Łęczyca of July 27, 2016 (case file I C 566/15), the judgment of the District Court for Łódź – Widzew in Łódź of August 13, 2020 (case file II C 1145/19), the judgment of the District Court in Pisz of August 21, 2020 (case file I C 260/20), or the judgment of the District Court in Puław of April 7, 2022 (case file I C 475/19).

It should therefore be emphasized that in accordance with the law and demonstrating care for the interests of the individuals concerned, the Administrator should have promptly ensured the best possible protection of personal data for the individuals concerned. To achieve this goal, it was necessary at least to indicate the information referred to in Article 34(2) in connection with Article 33(3)(c) and (d) of Regulation 2016/679, which obligation the Administrator failed to fulfill, despite a request directed to him in this matter on March 13, 2020, by the President of the Personal Data Protection Office (UODO).

Thus, based on the evidence gathered in this matter and in light of the arguments presented above, the allegation of the Administrator's violation of the obligation arising from Article 34(2) in connection with Article 33(3)(c) and (d) of Regulation 2016/679, due to the lack of proper notification of former and current employees about the violation of the protection of their personal data, should not raise any doubts. The analysis of the presented factual state also revealed that the Administrator has not made any further attempts to provide his former and current employees with a complete communication, i.e., taking into account all the elements mentioned in Article 34(2) of Regulation 2016/679 in connection with Article 33(3)(c) and (d) of Regulation 2016/679, despite the fact that after reading the request directed to him on March 13, 2020, by the President of the UODO, he should have already been aware of the rules for notifying individuals concerned about the violation of the protection of their personal data.

****VI. Administrative Monetary Penalty.****

In light of the above findings, the President of the UODO, exercising his powers specified in Article 58(2)(i) of Regulation 2016/679, considering the circumstances established in the relevant proceedings, determined that in the case at hand there were grounds justifying the imposition of administrative monetary penalties on the Administrator and the Processor.

According to Article 83(4)(a) of Regulation 2016/679, violations of the provisions concerning the obligations of the administrator and the processor, referred to in Articles 8, 11, 25 - 39, and 42 and 43, are subject to an administrative monetary penalty of up to EUR 10,000,000, and in the case of an enterprise – up to 2% of its total annual worldwide turnover from the previous financial year, with the higher amount applying.

According to Article 83(5)(a) of Regulation 2016/679, violations of the provisions concerning the basic

principles of processing, including the conditions for consent, referred to in Articles 5, 6, 7, and 9, are subject to an administrative monetary penalty of up to EUR 20,000,000, and in the case of an enterprise – up to 4% of its total annual worldwide turnover from the previous financial year, with the higher amount applying.

Article 83(3) of Regulation 2016/679 states that if the administrator or processor intentionally or unintentionally violates several provisions of this regulation within the same or related processing operations, the total amount of the administrative monetary penalty shall not exceed the amount of the penalty for the most serious violation.

In this administrative matter, a monetary penalty against Mr. AB, conducting business under the name X, at ul. (...), has been imposed for violating Article 25(1), Article 28(1), Article 32(1) and (2), and Article 34(2) in connection with Article 33(3)(c) and (d) of Regulation 2016/679 based on the aforementioned Article 83(4)(a) of Regulation 2016/679. Furthermore, for the violation of Article 5(1)(f) and Article 5(2) of Regulation 2016/679, the penalty is imposed based on Article 83(5)(a) of that regulation.

An administrative monetary penalty has also been imposed on Mr. EF and Mr. GH, partners of Y s.c., at Al. (...), and on Ms. CD, a former partner of Y s.c., all jointly liable, for violating Article 28(3)(f) in connection with Article 32(1) and (2) of Regulation 2016/679, based on Article 83(4)(a) of that regulation.

Moreover, it should be noted that according to the content of Article 58(2)(d) of Regulation 2016/679, each supervisory authority has the corrective power to order the controller or processor to bring processing operations into compliance with the provisions of this regulation, and where appropriate, to specify the manner and timeframe.

I. Conditions Affecting the Imposition of an Administrative Monetary Penalty Against the Controller (Article 83(2) in fine of Regulation 2016/679). In deciding to impose an administrative monetary penalty on Mr. AB, conducting business under the name X, at ul. (...), the President of UODO – in accordance with the provisions of Article 83(2)(a-k) of Regulation 2016/679 – took into account the following circumstances of the case, which are aggravating and influence the amount of the imposed administrative monetary penalty:

1. The nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing, the number of affected individuals whose data is concerned, and the extent of the damage suffered by them (Article 83(2)(a) of Regulation 2016/679). In determining the administrative monetary penalty, the circumstance that the violation of the provisions of Regulation 2016/679, imposing obligations on the Controller regarding the application of appropriate technical and organizational measures to ensure the security of personal data processed in connection with his nationwide business, the nature of which is described on page 3 of the justification of this decision, affected at least the availability of "(...) the database of customers who have made a purchase at least once (...)", as well as data concerning both former and current employees of the Controller "(...) numbering approximately 200 (...)" individuals, was of significant importance. A logical consequence of the identified deficiencies of the Controller in terms of compliance with the provisions of Article 24(1), Article 25(1), Article 32(1), and Article 32(2) of Regulation 2016/679 was the data breach that occurred on November 25, 2019, consisting of unauthorized access by unidentified perpetrators to the Controller's IT infrastructure and the encryption of the following categories of personal data of his former and current employees: "(...) first name(s), surname, parents' names, date of birth, bank account number, residential or temporary address, PESEL, email, series and number of the identity card, phone number." Thus, the violations of the aforementioned provisions of Regulation 2016/679 attributed to the Controller must be given considerable weight and seriousness, as the events resulting from them may lead to material or non-material damages for the category of individuals whose data has been breached in the above scope, and the likelihood of their occurrence remains high. It should be emphasized that the evidence gathered in this case does not show grounds supporting the likelihood of the Controller making appropriate determinations for the actual identification of the malicious software's mode of operation. Consequently, due to the lack of details provided by the

Controller regarding the conducted explanatory proceedings and its results, particularly the absence of sufficient evidence of actions taken by him to genuinely determine the mode of operation of the malicious software, it is impossible to unequivocally accept the truth of the assumption made by him, according to which "(...) the purpose of encrypting the data was not their theft (...)". On the contrary: in light of the stated facts, one cannot dismiss the scenario in which a breach of confidentiality of the aforementioned categories of personal data may have occurred, creating a high risk of negative consequences for the rights or freedoms of both former and current employees of X, ul. (...), which risk – importantly – was identified by the Controller himself, informing these individuals on March 21, 2020, about the potential consequences of the data breach, stating, "(...) The data affected by the breach may be used for purposes such as attempting to obtain other personal data from you, or attempting to enter into a contract with you (for example, online sales) using that data, executing a hacking attack by sending a notification to your email or phone number. There is also a chance that you will receive a commercial or marketing message that you did not consent to."

Even abstracting from considerations regarding real material damages that may arise – considering the set of categories of personal data and the context of processing – as a consequence of the breach of confidentiality of personal data (and their further disclosure to unauthorized entities, which cannot be excluded in this case either), it should be noted that the mere breach of availability... of personal data constitutes non-material damage (harm). The data subject may at least experience anxiety related to the loss of control over their personal data, which inconvenience directly arises from the nature of the violation of the availability attribute of that data, as well as the psychological suffering associated with uncertainty regarding further possible consequences of this violation, e.g., in the form of identity theft, identity fraud, or finally financial loss, not to mention, as rightly noted by the District Court in Warsaw in its judgment of August 6, 2020, case file XXV C 2596/19, that anxiety, and thus the loss of a sense of security, constitutes a real non-material damage associated with the obligation to remedy it. Furthermore, the Court of Justice of the EU in its ruling of December 14, 2023, regarding Natsionalna agentsia za prihodite (C-340/21) emphasized that "Article 82(1) of the GDPR should be interpreted in such a way that the fear of potential misuse of personal data by third parties, which a data subject experiences as a result of a breach of this regulation, may in itself constitute 'non-material damage' within the meaning of this provision."

2. The prolonged duration of the violation of the regulations of interest to the President of the UODO in the proceedings conducted by the authority requires particular emphasis. It should be pointed out that the state of violation of the provisions of Article 5(1)(f), Article 5(2), Article 25(1), Article 32(1) and (2) of Regulation 2016/679, manifested by: the lack of selection of effective technical measures ensuring a level of security appropriate to the risk of processing personal data, in particular through the use of an outdated server with software B.; the lack of regular testing, measuring, and evaluating the effectiveness of technical and organizational measures aimed at ensuring the security of personal data processed in the administrator's IT system, and thus the improper consideration of the risks associated with the processing of personal data in that system; the improper selection and lack of monitoring of organizational measures, allowing for modifications by employees of the antivirus software A., or finally the failure to implement appropriate organizational measures in the form of ensuring sufficient accountability regarding the training conducted for employees, which collectively constitute the basic premise for the occurrence of the subject violation of personal data protection, began on May 25, 2018, i.e., on the day the provisions of Regulation 2016/679 came into effect and has – in the absence of evidence of the Administrator conducting a risk analysis to identify and assess the appropriate level of risk associated with the processing of personal data – continued to this day. A similar perspective should be adopted regarding the ongoing violation of Article 28(1) of this regulation, which has persisted since May 24, 2018, i.e., from the moment the Administrator signed the data processing entrustment agreement with the Processor, to the present, as the Administrator admitted in a letter dated July 7, 2023, "(...) did not terminate the contract with Y as he still collaborates with this entity to some extent."

3. The unintentional nature of the violation (Article 83(2)(b) of Regulation 2016/679). Unauthorized

access to the Administrator's IT infrastructure, including to personal data processed in system d, became possible due to the Administrator's actions and evidence of his gross negligence, manifested both by his failure to conduct any risk analysis for the processes he designed before initiating personal data processing and by not conducting periodic evaluations in this regard after commencing the processing of personal data based on regular testing, measuring, and evaluating the technical and organizational security measures implemented in his organization for personal data processing processes, despite having knowledge of the updates offered by the software manufacturer. The logical consequence of the Administrator's gross negligence was – as established – the implementation of such technical and organizational measures to ensure the security of personal data processing processes in his organization, which could not adequately respond to the inherent risks associated with the data processing processes carried out within his structure even at the design stage.

Furthermore, by refraining from basing the security architecture designed in his organization on a prior risk analysis, the Administrator was a priori deprived – as demonstrated – of an effective assessment tool to determine whether the technical and organizational security measures he implemented were sufficient, while the lack of periodic checks of the tools he possessed and their assessment in terms of risk further exacerbated this state of ignorance. On the contrary, the Administrator, being aware of the nature of the data processing processes occurring in his organization, should have been conscious of the specifics of the functioning of IT systems and the impact that the "human factor" has on their operation. Despite using such systems for processing personal data, the Administrator not only failed to conduct a risk analysis in the area covered by the data protection violation but also, while designing and implementing changes aimed at mitigating the risk of a recurrence of the data protection violation, once again neglected to conduct a relevant threat evaluation. Thus, the characteristics of his actions should again be attributed to a lack of awareness regarding...

potential threats to the processes of personal data processing carried out within its structure, and the technical and organizational security measures implemented by the Administrator cannot be attributed adequacy in relation to the objectively existing risk. In this regard, no accusation can be formulated against the Administrator other than that concerning "gross negligence," understood as a failure to adhere to even the most elementary principles of conduct in a given situation, in other words, actions or omissions that do not meet the basic standards expressed in Article 5(1)(f) of Regulation 2016/679 regarding the principle of integrity and confidentiality, which consequently argues – in the opinion of the authority – for the intentional nature of the violation of the provisions of Article 25(1), Article 28(1), Article 32(1) and (2), which state of legal violation has not been remedied by the Administrator to this day.

3. Actions taken to minimize the damage suffered by the data subjects (Article 83(2)(c) of Regulation 2016/679). In this case, the action of the Administrator consisting of recovering access to encrypted data after 4 days cannot be considered as one that would actually contribute to minimizing damages of a material or non-material nature to the goods of the data subjects. It should be pointed out that the primary purpose of this action was to restore the functioning of the Administrator's enterprise, rather than consideration for the rights or interests of the individuals affected by the breach in question. This assessment of the authority is also based on the assumption made by the Administrator, which has no factual basis, according to which "(...) the purpose of encrypting the data was not their theft."

Meanwhile, the actual purpose of the perpetrators' actions remains unknown, and the *modus operandi* presented by them allows for a conclusion contrary to the Administrator's reasoning, which downplayed malicious intent as a motive for criminal action. Consequently, the actions taken by the Administrator do not in any way meet the requirement to minimize damages of a material and non-material nature to the goods of the data subjects. Fulfilling this obligation would constitute an initiative that could be realized by the Administrator, particularly related to apologies or monetary compensation to the data subjects. It is therefore obvious that the concentration of his actions solely on attempts to recover access to the database, which – importantly – does not determine the proper security of the data against further consequences of the breach, e.g., against their retrieval by other unauthorized entities, does not fit into this context. In light of the above circumstances, it becomes all the more difficult to seek a rational justification for the pragmatics adopted by the Administrator in

refraining from providing the data subjects with an accurate description of the possible consequences of the breach of personal data protection and a description of the measures applied or proposed by him to remedy the breach of personal data protection, including, where appropriate, measures to minimize its potential negative effects, which constitutes a failure by him to comply with the obligation specified in Article 34(2) in conjunction with Article 33(3)(c) and (d) of Regulation 2016/679.

4. The degree of cooperation with the supervisory authority to remedy the breach and mitigate its potential negative effects (Article 83(2)(f) of Regulation 2016/679). The shortcomings demonstrated during these proceedings and attributable to the Administrator fit into the context of his gross – due to its persistence – lack of cooperation with the supervisory authority, resulting in the failure to remedy the state of violation of the provisions of Article 24(1), Article 25(1), Article 32(1) and (2), and Article 34(2) in conjunction with Article 33(3)(c) and (d) of Regulation 2016/679, despite the formal initiation of administrative proceedings in this matter by the President of the UODO.

5. Categories of personal data affected by the breach (Article 83(2)(g) of Regulation 2016/679). The personal data processed in system d. did not belong to special categories of personal data referred to in Article 9(1) of Regulation 2016/679; however, their broad scope, including such categories of data of natural persons as: PESEL number, series and number of the identity card, first names and surnames, parents' names, date of birth, bank account number, residential or temporary address, email address, and phone number, is associated with a high risk of violation of the rights or freedoms of the natural persons affected by the breach in question. It should be emphasized that the unauthorized disclosure of such a category of data of a special nature as the PESEL number, which is an eleven-digit numerical symbol that uniquely identifies a natural person, containing the date of birth, serial number, gender designation, and control number, remaining closely linked to the privacy sphere of the natural person and also subject to exceptional protection under Article 87 of Regulation 2016/679, particularly in conjunction – as was the case in this matter – with a broader set of personal data, can realistically and negatively affect the protection of the rights or freedoms of the natural persons. The same applies to the special nature of the identification information, such as the PESEL identification number, and the associated demand for its special protection, as expressed by the Provincial Administrative Court in Warsaw, which in its judgment of July 1, 2022, stated that "in the case of a breach of such data as first name, surname, and PESEL number, identity theft or forgery is possible, resulting in negative consequences for...

"data subjects." Importantly, a similar view was expressed by the Supreme Administrative Court, which in its ruling of December 6, 2023 (judgment of the Supreme Administrative Court of December 6, 2023, case file III OSK 2931/21) noted that the disclosure of "(...) data including first and last names, as well as PESEL numbers of natural persons, and thus relatively permanent, unchanging data (...) may always pose a risk of negative consequences for the aforementioned persons."

As indicated in the EROD Guidelines 04/2022 regarding the calculation of administrative fines under the GDPR (p. 22; version 2.1; adopted on May 24, 2023), hereinafter referred to as Guidelines 04/2022, "Regarding the requirement to consider the categories of personal data involved in the breach (Article 83(2)(g) GDPR), the GDPR explicitly indicates the types of data that are subject to special protection, and thus a more stringent response when imposing monetary penalties. This concerns at least the types of data covered by Articles 9 and 10 of the GDPR, as well as data not covered by the scope of these articles, the dissemination of which immediately causes harm or discomfort to the data subject (e.g., location data, private communication data, national identification numbers, or financial data such as transaction statements or credit card numbers). Generally speaking, the more categories of such data involved in the breach or the more sensitive the data, the greater weight the supervisory authority may assign to this factor."

In determining the amount of the administrative fine for the Administrator, the President of the UODO found no grounds to consider mitigating circumstances that would affect the final penalty. All the criteria listed in Article 83(2)(a) – (j) of Regulation 2016/679, in the assessment of the supervisory authority, constitute either aggravating factors or are merely neutral. Also, applying the criterion mentioned in Article 83(2)(k) of Regulation 2016/679 (which requires consideration of any other

aggravating or mitigating factors applicable to the circumstances of the case), no mitigating circumstances were found, only neutral ones (as noted below in point 7).

Other circumstances mentioned in Article 83(2) of Regulation 2016/679, after assessing their impact on the identified breach in this case, were deemed by the President of the UODO to be neutral in his assessment, meaning they had neither an aggravating nor a mitigating effect on the amount of the imposed administrative fine.

1. Degree of responsibility of the administrator considering the technical and organizational measures implemented by him under Articles 25 and 32 (Article 83(2)(d) of Regulation 2016/679). As indicated by EROD in Guidelines 04/2022, when considering the aforementioned criterion, “the supervisory authority must answer the question of to what extent the administrator ‘did everything that could be expected,’ considering the nature, purposes, or scope of processing and in light of the obligations imposed on him by the regulation.”

The supervisory authority found in this case that the Administrator violated the provisions of Article 25(1) and Article 32(1) and (2) of Regulation 2016/679. In the opinion of the President of the UODO, he bears a high degree of responsibility for failing to implement appropriate technical and organizational measures that could have prevented the breach of personal data protection. It is evident that in the context of the nature, purpose, and scope of processing personal data, the Administrator did not do everything that could be expected, thus failing to fulfill the obligations imposed on him under Articles 25 and 32 of Regulation 2016/679. However, in this case, this circumstance constitutes the essence of the breach itself and is not merely a factor influencing – either aggravating or mitigating – its assessment. For this reason, the lack of appropriate technical and organizational measures referred to in Articles 25 and 32 of Regulation 2016/679 cannot be considered in this case as a circumstance that could additionally influence the assessment of the breach and the amount of the administrative fine imposed on the Administrator.

2. Any relevant prior violations by the administrator (Article 83(2)(e) of Regulation 2016/679). The President of the UODO did not find any prior violations of data protection regulations on the part of the Administrator, which means there are no grounds to treat this circumstance as aggravating. It is the duty of every administrator to comply with the law, and therefore the lack of prior violations cannot also be a mitigating circumstance when imposing sanctions.

3. The manner in which the supervisory authority became aware of the breach, in particular, whether and to what extent the administrator reported the breach (Article 83(2)(h) of Regulation 2016/679). The President of the UODO found that the Administrator violated data protection regulations as a result of his reporting of the personal data breach. By making the report, the Administrator was fulfilling a legal obligation, and therefore there are no grounds to consider this fact as a mitigating circumstance.

EROD indicates in Guidelines 04/2022 that “the manner in which the supervisory authority became aware of the breach may constitute a significant aggravating or mitigating circumstance. In assessing this aspect, particular weight may be given to the question of whether the administrator or processor notified the supervisory authority of the breach on their own initiative, and if so, to what extent, before the supervisory authority was informed of the breach through – for example – a complaint or proceedings. This circumstance is irrelevant when the administrator is subject to...”

specific obligations regarding the reporting of violations (such as the obligation to report a personal data breach specified in Article 33 of the GDPR). In such cases, the fact of making a report should be considered a neutral circumstance.

4. If measures referred to in Article 58(2) have previously been applied to the administrator in the same matter – compliance with these measures (Article 83(2)(i) of Regulation 2016/679). Prior to issuing this decision, the President of the UODO did not apply any measures listed in Article 58(2) of Regulation 2016/679 to the Administrator in the case at hand, and therefore, he had no obligation to take any actions related to their implementation, which actions, when assessed by the supervisory authority, could have a burdensome or mitigating effect on the assessment of the established violation.

5. The application of approved codes of conduct under Article 40 or approved certification mechanisms

under Article 42 (Article 83(2)(j) of Regulation 2016/679). The Administrator does not apply approved codes of conduct or approved certification mechanisms referred to in the provisions of Regulation 2016/679. However, their adoption, implementation, and application are not – as provided for in the provisions of Regulation 2016/679 – mandatory for administrators, which means that the circumstance of their non-application cannot be considered detrimental to the Administrator in this case. On the other hand, the circumstance of adopting and applying such instruments could be taken into account in favor of the Administrator, as measures guaranteeing a higher than standard level of protection of personal data processing.

6. Financial benefits gained directly or indirectly in connection with the violation or avoidance of loss (Article 83(2)(k) of Regulation 2016/679). The President of the UODO did not find that, in connection with the violation, the Administrator gained any financial benefits or avoided such losses. Therefore, there are no grounds for treating this circumstance as burdensome for the Administrator. The establishment of measurable financial benefits resulting from the violation of the provisions of Regulation 2016/679 should be assessed decidedly negatively. The lack of such benefits achieved by the Administrator, as a natural state independent of the violation and its effects, is a circumstance that inherently cannot be mitigating for the Administrator. This interpretation is confirmed by the very wording of Article 83(2)(k) of Regulation 2016/679, which requires the supervisory authority to pay due attention to the benefits "gained" – that is, those that occurred on the part of the entity committing the violation.

7. Other aggravating or mitigating factors applicable to the circumstances of the case (Article 83(2)(k) of Regulation 2016/679). The President of the UODO, comprehensively considering the case, did not note any circumstances other than those described above that could influence the assessment of the violation and the amount of the imposed administrative monetary penalty. Taking into account all the circumstances discussed above, the President of the Personal Data Protection Office concluded that imposing an administrative monetary penalty on the Administrator is necessary and justified by the seriousness, nature, and scope of the alleged violations of the provisions of Regulation 2016/679. It should be stated that the application of any other corrective measure provided for in Article 58(2) of Regulation 2016/679 to these entities, especially merely issuing a reprimand (Article 58(2)(b) of Regulation 2016/679), would not be proportional to the identified irregularities in the personal data processing and would not guarantee that the aforementioned entities would not commit similar negligence in the future, as in the present case.

II. Method of calculating the penalty against the Administrator based on Guidelines 04/2022 on calculating administrative monetary penalties under the GDPR. It is necessary to indicate that in determining the amount of the administrative monetary penalty against the Administrator in this case, the President of the UODO applied the methodology adopted by the European Data Protection Board in Guidelines 04/2022. According to the guidance presented in this document:

1. The President of the UODO categorized the identified violations of the provisions of Regulation 2016/679 in this case (see Chapter 4.1 of Guidelines 04/2022). The violations identified in this case of Articles 5(1)(f) and 5(2) of Regulation 2016/679 belong – according to Article 83(5) of Regulation 2016/679 – to the category of violations subject to a higher penalty of the two provided for in Regulation 2016/679 (with a maximum amount of up to EUR 20,000,000 or up to 4% of the total annual turnover of the enterprise from the previous financial year). They have thus been in abstracto (in isolation from the individual circumstances of the specific case) recognized by the EU legislator as more serious than the violations indicated in Article 83(4) of Regulation 2016/679.

2. The President of the UODO assessed the violations identified in this case as violations of medium severity (see Chapter 4.2 of Guidelines 04/2022). In this assessment, the factors among those listed in Article 83(2) of Regulation 2016/679 that pertain to the subject matter of the violations (constituting the "seriousness" of the violation), namely: the nature, gravity, and duration of the violations (Article 83(2)(a) of Regulation 2016/679), the unintentional nature of the violations (Article 83(2)(b) of Regulation 2016/679), and the categories of personal data affected by the violations (Article 83(2)(g) of Regulation 2016/679) were taken into account. A detailed assessment of these circumstances has

been presented above. It should be noted here that considering their cumulative impact on the assessment...

identified in this case violations treated in their entirety leads to the conclusion that the level of their seriousness also in concreto is medium (on the scale of the seriousness of violations presented in point 60 of Guidelines 04/2022). Consequently, this results in the acceptance – as the starting amount for calculating the fine – of a value falling within the range of 10 to 20% of the maximum fine that can be imposed on the Administrator. Considering that Article 83(5) of Regulation 2016/679 obliges the President of the UODO to adopt as the maximum fine for the violations indicated in this provision the amount of 20,000,000 EUR or – if this amount is higher than 20,000,000 EUR – an amount equal to 4% of the enterprise's turnover from the previous financial year, the President of the UODO concluded that the so-called static maximum fine amount, i.e., 20,000,000 EUR, applies in this case, which is higher than – resulting from the application of the 4% indicator applied to the Administrator's turnover for 2023, which amounted to (...) EUR. Having at his disposal a range from 2,000,000 EUR to 4,000,000 EUR, the President of the UODO accepted, as adequate and justified by the circumstances of the case, the starting amount for calculating the fine of (...) EUR (which constitutes (...) % of the static maximum fine amount).

3. In accordance with the guidance of the European Data Protection Board presented in point 65 of Guidelines 04/2022 (with respect to enterprises whose annual turnover is between 10 and 50 million EUR), the President of the UODO deemed it appropriate to take advantage of the possibility of reducing the starting amount adopted based on the assessment of the seriousness of the violation, which this guidance (in Chapter 4.3) provides for smaller enterprises with less economic power. In point 65 of Guidelines 04/2022, the EDPB indicates that "(...) In the case of enterprises whose annual turnover is between 10 and 50 million EUR, supervisory authorities may consider calculating based on a value in the range of 1.5 to 10% of the identified starting amount." Consequently, the President of the UODO, taking into account the size of the Administrator's organization measured by its turnover, considered it justified to adjust the starting amount of the administrative monetary fine to (...) % of the starting amount, i.e., to the amount of (...) EUR (which is equivalent to (...) PLN).

4. The President of the UODO assessed the impact on the identified violation of other circumstances (besides those considered above in the assessment of the seriousness of the violation) indicated in Article 83(2) of Regulation 2016/679 (vide Chapter 5 of Guidelines 04/2022). These circumstances, which may have an aggravating or mitigating effect on the assessment of the violation, relate – as assumed by Guidelines 04/2022 – to the subjective side of the violation, that is, to the entity itself that committed the violation and to its behavior before the violation, during it, and after its occurrence. A detailed assessment and justification of the impact of each of these factors on the assessment of the violation have been presented above. The President of the UODO concluded (which was justified in the above-presented part of the decision's justification) that the aggravating circumstances in this case, and thus additionally increasing the extent of the penalty imposed by this decision, are the actions taken by the Administrator to minimize the damage suffered by the data subjects (Article 83(2)(c) of Regulation 2016/679), as well as the degree of cooperation of the Administrator with the President of the UODO in order to remedy the violation and mitigate its potential negative effects (Article 83(2)(f) of Regulation 2016/679). The remaining factors (from Article 83(2)(d), (e), (h), (i), (j), (k) of Regulation 2016/679) – as indicated above – did not have an impact, either mitigating or aggravating, on the assessment of the violation and consequently on the extent of the penalty. Therefore, due to the existence of additional aggravating circumstances in the case, related to the subjective side of the violations (the assessment of the Administrator's conduct before and after the violations), the President of the UODO deemed it justified to increase the amount of the penalty determined based on the assessment of the seriousness of the violations (point 2 above) and the size and economic power of the Administrator (point 3 above). According to the President of the UODO, an appropriate increase in light of the impact of these factors on the assessment of the violations is to raise it to the amount of (...) PLN, which is equivalent to (...) EUR.

5. The President of the UODO stated that the amount of the administrative monetary fine determined

in the manner presented above does not exceed – according to Article 83(3) of Regulation 2016/679 – the legally defined maximum amount of the fine provided for the most serious violation (vide Chapter 6 of Guidelines 04/2022). In the case of the most serious violation, namely the violation of the provisions of Article 5(1)(f) and Article 5(2) of Regulation 2016/679, the legally defined maximum amount of the fine (static) is, as indicated above in point 1, 4,000,000 EUR. Therefore, the amount of the fine specified above, which is equivalent to (...) EUR, obviously does not exceed the maximum penalty provided for the most serious of the identified violations.

6. Although the amount of the fine determined according to the above principles does not exceed the legally defined maximum fine, the President of the UODO considered that it requires additional adjustment due to the principle of proportionality mentioned in Article 83(1) of Regulation 2016/679 as one of the three directives for determining the penalty (vide Chapter 7 of Guidelines 04/2022). Undoubtedly, a monetary fine of (...) EUR would be an effective penalty (due to its severity, it would achieve its punitive purpose, which is to punish for unlawful behavior) and deterrent (allowing effectively to discourage both this specific Administrator and other administrators from committing violations of the provisions of Regulation 2016/679 in the future). However, such a penalty would be – in the opinion of the President of the UODO – a disproportionate penalty both in relation to the seriousness of the identified violations (which, although in abstracto... is greater, but in concreto remains average – see points 1 and 2 above), as well as due to its excessive – in relation to this weight – burden. The principle of proportionality requires, among other things, that the measures adopted by the administrative authority do not exceed what is appropriate and necessary to achieve legitimate objectives (see points 137 and 139 of Guidelines 04/2022). In other words: "A sanction is proportional if it does not exceed the threshold of burden determined by taking into account the circumstances of the specific case" (P. Litwiński (ed.), Regulation of the European Parliament and of the Council (EU) 2016/679 of April 27, 2016 [...]; Commentary on Article 83 in: P. Litwiński (ed.) General Regulation on Data Protection. Data Protection Act. Selected sectoral provisions. Commentary). Therefore, taking into account the proportionality of the penalty, the President of the UODO further reduced the amount of the fine to EUR 81,000 (equivalent to PLN 353,589). In his opinion, such determination of the final amount of the imposed fine will not affect its effectiveness and deterrent nature. This amount constitutes a threshold above which further increases in the amount of the fine will not be associated with an increase in its effectiveness and deterrent nature. On the other hand, a greater reduction in the amount of the fine could occur at the expense of its effectiveness and deterrent nature, as well as a coherent understanding, application, and enforcement of Regulation 2016/679 in relation to other supervisory authorities and the EDPB, as well as the principle of equal treatment of entities in the EU and EEA internal market.

III. Directives on effectiveness, proportionality, and deterrent nature of the sanction applied against the Administrator (Article 83(1) of Regulation 2016/679).

In the opinion of the President of the UODO, the administrative fine imposed on Mr. AB, conducting business under the name X, at ul. (...) fulfills the functions referred to in Article 83(1) of Regulation 2016/679 in the established circumstances of this case, i.e., it is effective, proportional, and deterrent in this individual case. The fine will be effective if its imposition leads to the Administrator fulfilling his obligations regarding personal data protection in the future, particularly in the aspect of: implementing appropriate technical and organizational measures ensuring the security of data processing in IT systems and protecting the rights of data subjects, based on a risk analysis taking into account the state of technical knowledge, cost of implementation, nature, scope, context, and purposes of processing, as well as the risk of infringement of the rights or freedoms of natural persons; implementing appropriate technical and organizational measures to ensure regular testing, measuring, and assessing the effectiveness of technical and organizational measures aimed at ensuring the security of personal data processed in IT systems, particularly in terms of vulnerabilities, errors, and their possible consequences for these systems, as well as actions taken to minimize the risk of their occurrence; implementing appropriate technical and organizational measures ensuring the ability to quickly restore the availability of personal data and access to it in the event of a physical or technical

incident.

In the opinion of the President of the UODO, the administrative fine will serve a repressive function, as it will constitute a response to the Administrator's violation of the provisions of Regulation 2016/679. It will also serve a preventive function, as – in the opinion of the President of the UODO – it will indicate both to this specific Administrator and to other data controllers the reprehensibility of neglecting their obligations related to: implementing appropriate technical and organizational measures ensuring the security of data processing in IT systems and protecting the rights of data subjects, based on a risk analysis taking into account the state of technical knowledge, cost of implementation, nature, scope, context, and purposes of processing, as well as the risk of infringement of the rights or freedoms of natural persons; implementing appropriate technical and organizational measures to ensure regular testing, measuring, and assessing the effectiveness of technical and organizational measures aimed at ensuring the security of personal data processed in IT systems, particularly in terms of vulnerabilities, errors, and their possible consequences for these systems, as well as actions taken to minimize the risk of their occurrence; implementing appropriate technical and organizational measures ensuring the ability to quickly restore the availability of personal data and access to it in the event of a physical or technical incident; verifying the data processor to ensure sufficient guarantees of implementing appropriate technical and organizational measures so that processing meets the requirements of Regulation 2016/679 and protects the rights of data subjects; with the occurrence of a personal data breach, which is intended to prevent its negative and often severe consequences for the individuals whose rights have been breached, as well as to eliminate these consequences or at least limit them.

Pursuant to Article 103 of the UODO, the equivalent amounts expressed in euros referred to in Article 83 of Regulation 2016/679 are calculated in zlotys according to the average euro exchange rate announced by the National Bank of Poland in the exchange rate table on January 28 of each year, and in the event that the National Bank of Poland does not announce the average euro exchange rate on January 28 of a given year – according to the average euro exchange rate announced in the nearest table of exchange rates of the National Bank of Poland after this date.

Taking the above into account, the President of the Personal Data Protection Office (UODO), based on Article 83(5) in connection with Article 103 of the Personal Data Protection Act, imposed on the Administrator – applying the average exchange rate of the euro from January 29, 2024 (1 EUR = 4.3653 PLN) – an administrative fine in the amount of 353,589 PLN (which is equivalent to 81,000 EUR) for the violation described in the operative part of this decision.

In the opinion of the President of UODO, the administrative fine imposed on the Administrator in the amount of 353,589 PLN (in words: three hundred fifty-three thousand five hundred eighty-nine zlotys) meets the conditions referred to in Article 83(1) of Regulation 2016/679 due to the seriousness of the identified violation in the context of the primary objective of Regulation 2016/679 – the protection of fundamental rights and freedoms of natural persons, in particular the right to personal data protection. Referring to the amount imposed on Mr. AB, conducting business under the name X, at ul. (...), the President of UODO considered that it is proportional to the financial situation of the Administrator and will not constitute an excessive burden for him.

From the statement presented by the Administrator on March 8, 2024, it follows that “(...) the revenue for the year 2023 amounted to (...) PLN,” which means that the amount of the administrative fine imposed in this case constitutes approximately (...) % of the aforementioned value. At the same time, it should be emphasized that the amount of the imposed fine is merely (...) % of the maximum amount of the fine that the President of UODO could – in accordance with Article 83(5) of Regulation 2016/679, with a maximum fine of up to 20,000,000 EUR – impose on the Administrator for the violations identified in this case.

The amount of the fine was determined at such a level that, on the one hand, it constitutes an adequate response of the supervisory authority to the degree of violation of the Administrator's obligations, while on the other hand, it does not create a situation in which the necessity to pay the

financial penalty would lead to negative consequences, such as a significant reduction in employment or a substantial decrease in its turnover. In the opinion of the President of UODO, the Administrator should and is able to bear the consequences of his negligence in the area of data protection, as evidenced by the aforementioned statement dated March 8, 2024.

At the same time, the President of UODO, based on Article 83(3) of Regulation 2016/679, decided to impose a single penalty for the entirety of the violations attributed to the Administrator in the proceedings with reference number DKN.5131.1.2021. This is because the events exemplifying them are contextually, spatially, and temporally linked, and according to Guidelines No. 4/2022, they should be treated as a single behavior of the Administrator, leading to the imposition of a single monetary penalty (point 28 of the Guidelines). In light of the evidence gathered during this proceeding, it should be noted that the materialization of the risk, which resulted in the loss of availability of the Administrator's resources on November 25, 2019, was the effect of an inadequately designed data processing security system by him and the lack of regular testing of potential vulnerabilities in the IT infrastructure. Furthermore, the issuance of a faulty notification to the individuals whose data are concerned should be considered in the context of the Administrator's response to the occurrence of the identified violation of personal data protection.

IV. Circumstances influencing the imposition of an administrative fine on the Processor (Article 83(2) in fine of Regulation 2016/679). In deciding to impose an administrative fine on Ms. CD, Mr. EF, and Mr. GH, who are partners of Y s.c. during the period of the identified violations in this case, the President of UODO – in accordance with the provisions of Article 83(2)(a)-(k) of Regulation 2016/679 – took into account the following circumstances of the case, which are aggravating and influence the amount of the imposed administrative fine.

1. The nature, gravity, and duration of the violation, taking into account the nature, scope, or purpose of the processing, the number of affected individuals whose data are concerned, and the extent of the damage suffered by them (Article 83(2)(a) of Regulation 2016/679). A decisive circumstance for imposing an administrative fine on the individuals who were partners of Y s.c. during the period of the identified violations in this case was the failure by Ms. CD, Mr. EF, and Mr. GH to comply with the provisions of Regulation 2016/679, which impose obligations on the processor to assist the Administrator in maintaining adequate security measures for personal data processing, namely Article 28(3)(f) in connection with Article 32(1) and (2) of this Regulation. This assistance should consist of informing the Administrator about the lack of appropriate security for the server used by him in the processes of personal data processing, regardless of whether the consequence of this lack was its use by the perpetrators of the ransomware attack and – as in this case – the occurrence of a personal data breach, or not. As stated in Article 28(3)(f) of Regulation 2016/679, this assistance should be provided to the Administrator based on “the information available to him” (held in this case by the Processor in connection with the services provided to the Administrator) and due to the “nature of the processing” (referring to the same personal data – processed in system d., stored on the Administrator's server, and used by him in his business activities, the nature of which has been outlined).

Page 4 of the justification for this decision). Contrary to the literal wording of Article 28(3)(f) of Regulation 2016/679, the assistance referred to therein goes beyond the contractual relationships arising from the agreement concluded on May 24, 2018, between the Administrator and the Processor “(...)”, which establishes the processor's liability for actions “(...) in the area of managing, operating, and maintaining the system in the Administrator's enterprise.” A broader understanding of the term “assistance” applies here, thus (according to the PWN Polish Language Dictionary): “actions taken for the benefit of another person.” Furthermore, “to assist” means (again according to the PWN Polish Language Dictionary) “to make some effort for the benefit of someone, to facilitate something for them or to help them in a difficult situation; also: to give someone something.” Meanwhile, the indolence displayed by the Processor in cooperation with the Administrator not only did not facilitate the Administrator's understanding (which, as a non-professional entity, he was not required to possess) regarding the technical and organizational security measures maintained by him for the data processing processes occurring within his structure, but directly contributed to the occurrence of the

event on November 25, 2019. The passivity exhibited by the Processor in this case, manifested by the failure over the years to inform the Administrator about vulnerabilities in the server software (while one of them was successfully exploited by the perpetrators of the criminal act) and the necessity to update the operating system to the latest possible version, or to apply other, newer logical solutions, remains directly linked to the materialization of the risk in the form of unauthorized access by unidentified perpetrators to the Administrator's IT infrastructure. The consequence of the occurrence of the aforementioned breach of personal data protection processed on the Administrator's servers was – at the very least – the encryption of “(...) the database of clients who have made a purchase at least once (...)”, as well as data concerning both former and current employees of the Administrator “(...) numbering approximately 200 (...)” individuals. The demonstrated breach of the aforementioned provisions of Regulation 2016/679 by the Processor must also be attributed – due to the categories of data concerning former and current employees of the Administrator covered by it, i.e. “(...) first name(s), last name, parents' names, date of birth, bank account number, residential or temporary address, PESEL, email, series and number of the identity card, phone number” – significant weight and serious nature. The personal data breach that occurred on November 25, 2019, to which the individuals who were partners of Y s.c. at the time contributed with their behavior – excluding the possibility of providing real support to the Administrator – may lead to material or non-material damages for the data subjects, and the likelihood of their occurrence remains high. It should be emphasized that the evidence gathered in this case does not show any grounds for establishing that the Administrator made appropriate determinations to genuinely identify the manner of operation of the malicious software. Consequently, with respect to the aforementioned categories of individuals whose data has been breached, there continues to exist a high risk of unlawful use of their personal data, as the purpose of the actions of unauthorized individuals remains unknown. The above argumentation is further strengthened considering the *modus operandi* of the perpetrators of a criminal nature, for whom, due to their *modus operandi*, bad faith should be assumed as the motive for their actions. The individuals whose data is concerned may therefore continue to suffer material harm, and the mere breach of the availability of their data also constitutes non-material harm (injury). The data subject may at least feel anxiety related to the loss of control over their personal data, which inconvenience directly arises from the nature of the breach of the attribute of availability of that data, as well as the psychological suffering associated with uncertainty regarding the further possible consequences of this breach, e.g., in the form of identity theft, identity fraud, or finally financial loss, not to mention, as rightly noted by the District Court in Warsaw in the judgment of August 6, 2020, case file XXV C 2596/19, that fear, and thus the loss of a sense of security, constitutes a real non-material harm associated with the obligation to remedy it. Furthermore, the Court of Justice of the EU in its ruling of December 14, 2023, in the case of *Natsionalna agentsia za prihodite* (C-340/21) emphasized that “Article 82(1) of the GDPR should be interpreted in such a way that the fear of potential misuse of personal data by third parties, which a data subject experiences as a result of a breach of this regulation, may in itself constitute ‘non-material damage’ within the meaning of this provision.”

Regardless of the above, it is also necessary to highlight the fact of the prolonged period of the Processor's violation of the provisions of Article 28(3)(f) in connection with Articles 32(1) and (2) of Regulation 2016/679. Based on the findings made during this proceeding, it should be accepted that the described state of legal violation existed at least since May 24, 2018, i.e., from the moment the Administrator signed the data processing entrustment agreement with the Processor, at the latest until April 10, 2020, when the Administrator informed the authority about actions taken “(...) to strengthen the security of the processed personal data (...)”, among which should be mentioned, *inter alia*: “(...) complete withdrawal from the use of the system, on... which led to the infection (...); updating operating systems to the latest available versions, including changing the operating system (...) to the system (...) (...). It should also be emphasized that the increase in risk in the form of the activation of foreign processes on the Administrator's server could have been avoided if the Data Processor, in accordance with Article 28(3)(f) of Regulation 2016/679, had properly fulfilled its obligation to provide the Administrator with “assistance” taking into account the “information available to it.”

2. The unintentional nature of the breach (Article 83(2)(b) of Regulation 2016/679). The Data Processor, providing professional services, including IT system management, and possessing appropriate knowledge in this area, failed to comply with one of its fundamental obligations required of it under Article 28(3)(f) of Regulation 2016/679, which is to provide the Administrator with "assistance" that takes into account "the information available to it." Despite having knowledge regarding the outdated software used by the Administrator in the processing of personal data (and therefore vulnerable to threats that ultimately materialized), the partners of Y s.c. did nothing, additionally over a long period of time, to counteract this state of affairs. Their omissions therefore exclude the possibility of providing assistance, understood as giving the Administrator real support regarding the technical and organizational security measures implemented by him, which, as a non-professional in the field of IT, he did not have to fully understand. Undoubtedly, from a professional entity, especially one possessing: "(...) many years of experience in implementing systems based on (...) and adapting them to the individual needs of the client (...)" and distinguished not only by having the "(...) most experienced implementation team in Poland (...)", but also by the status of "(...)", one can require that based on "the information available to it" (which it must have possessed due to the fact that it oversaw system d. located on the mentioned server) it supported its partner with expert knowledge. The findings made by the President of UODO therefore allow for the conclusion that the attitudes of the partners of Y s.c. cannot be described in terms other than those relating to gross negligence, which, considering the professional nature of the services provided by this entity, must constitute an aggravating circumstance.

3. Categories of personal data affected by the breach (Article 83(2)(g) of Regulation 2016/679). The personal data processed in system d. did not belong to special categories of personal data referred to in Article 9(1) of Regulation 2016/679; however, their broad scope, including such categories of data of natural persons as: PESEL number, series and number of the identity card, first and last names, names of parents, date of birth, bank account number, residential or temporary address, email address, and phone number, is associated with a high risk of infringement of the rights or freedoms of the natural persons affected by the breach in question. It should be emphasized that the unauthorized disclosure of such a category of data with a special character as the PESEL number (which, in light of evidence to the contrary, cannot be excluded in the presented factual state), i.e., an eleven-digit numerical symbol that unequivocally identifies a natural person, containing the date of birth, ordinal number, gender designation, and control number, remains closely linked to the privacy sphere of the natural person and is also subject, as a national identification number, to exceptional protection under Article 87 of Regulation 2016/679, particularly in conjunction – as was the case in this matter – with a broader set of personal data, can realistically and negatively affect the protection of the rights or freedoms of natural persons. The same applies to the special character of the identification information, such as the PESEL identification number, and the associated demand for its special protection has been expressed by the Provincial Administrative Court in Warsaw, which in its judgment of July 1, 2022, stated that "in the case of a breach of such data as first name, last name, and PESEL number, identity theft or forgery is possible, resulting in negative consequences for the persons whose data are concerned." Importantly, a similar view was expressed by the Supreme Administrative Court, which in a ruling issued on December 6, 2023 (judgment of the Supreme Administrative Court of December 6, 2023, case file III OSK 2931/21) noted that the disclosure of "(...) data including first and last names, as well as PESEL numbers of natural persons, and thus relatively permanent, unchanging data (...) always carries the risk of negative consequences for the aforementioned persons." As indicated in the EROD Guidelines 04/2022, "Regarding the requirement to consider the categories of personal data affected by the breach (Article 83(2)(g) of the GDPR), the GDPR clearly specifies the types of data that are subject to special protection, and thus a more rigorous response when imposing monetary penalties. This applies at least to the types of data covered by Articles 9 and 10 of the GDPR and data not covered by the scope of these articles, the dissemination of which immediately causes harm or discomfort to the person concerned (e.g., data concerning location, data concerning private communication, national identification numbers, or financial data such as transaction statements or credit card numbers). Generally speaking, the greater the number of such categories of data affected

by the breach or the more sensitive the data, the greater weight the supervisory authority may assign to this factor." In determining the amount of the administrative monetary penalty, The President of the UODO did not find grounds to consider mitigating circumstances that would affect the final amount of the penalty. All the conditions listed in Article 83(2)(a) – (j) of Regulation 2016/679, in the assessment of the supervisory authority, are either aggravating factors or merely neutral. Also, applying the condition mentioned in Article 83(2)(k) of Regulation 2016/679 (which requires taking into account any other aggravating or mitigating factors relevant to the circumstances of the case), no mitigating circumstances were found, only neutral ones (as noted below in point 9).

Other circumstances indicated below, referred to in Article 83(2) of Regulation 2016/679, after assessing their impact on the established violation in this case, were deemed neutral by the President of the UODO, meaning they had neither an aggravating nor a mitigating effect on the amount of the imposed administrative monetary penalty.

1. Actions taken to minimize the damage suffered by the data subjects (Article 83(2)(c) of Regulation 2016/679). In this case, the characterization presented in the letter dated July 8, 2022, by the former and current partners of Y s.c., Al. (...) regarding the actions they undertook after the occurrence of the data protection violation cannot be considered as actually contributing to the minimization of damages of a material or non-material nature to the goods of the data subjects. The action of "(...) disconnecting the server from the network (...)" could not have contributed in any way to minimizing these damages, as unauthorized access to the Administrator's IT infrastructure, which resulted in the loss of availability and – as demonstrated and which cannot be excluded – confidentiality of the personal data processed using it, occurred prior to the action taken by the Data Processor. Consequently, the technical measure applied by the processor, which did not contribute in any way to the decryption of personal data, and even less could restore the attribute of their confidentiality, cannot be perceived in the established circumstances of this case as a measure that would eliminate the likelihood of a high risk of infringement of the rights or freedoms of natural persons. Similarly, the information provided by the Data Processor about "(...) decrypting the database [containing personal data – ed. note]" should be treated. The authority refused to recognize the evidentiary value of the circumstances cited by the former and current partners of Y s.c., guided by the criteria of both the type of malware used by the perpetrators and considering the fact that before November 25, 2019, the Administrator's IT infrastructure did not utilize solutions based on network segmentation, which consequently must have led to the effects of the ransomware attack encompassing the entire structure, including backup copies, making it impossible to restore the processed personal data other than by using decryption codes. On the other hand, the other remedial actions described by the Data Processor in the mentioned letter should, in the opinion of the President of the UODO, rather be considered in terms of technical and organizational measures mitigating the risk of a recurrence of the data protection violation, rather than those taken to minimize the damage suffered by the data subjects in the context of this specific violation.

2. Degree of responsibility considering the implemented technical and organizational measures (Article 83(2)(d) of Regulation 2016/679). As indicated by the EDPB in Guidelines 04/2022, when considering the aforementioned criterion, "the supervisory authority must answer the question of the extent to which the administrator 'did everything that could be expected,' given the nature, purposes, or scope of the processing and in light of the obligations imposed on it by the regulation." The above criterion also allows for the assignment of potential responsibility and its degree to the data processor. Consequently, the assessment of the data processor under the aforementioned Guidelines in the context of applying an appropriate remedial measure may relate to Article 32 of Regulation 2016/679 and encompass the issue of ensuring an appropriate level of security. The supervisory authority found in this case that the Data Processor violated the provisions of Article 32(1) and (2) of Regulation 2016/679. In the opinion of the President of the UODO, there is a high degree of responsibility on it for failing to implement appropriate technical and organizational measures that could have prevented the violation of personal data protection. It is evident that in the considered context of the nature, purpose, and scope of the processing of personal data, the Data Processor did not do everything that could be

expected, thus failing to fulfill the obligations imposed on it by Article 32 of Regulation 2016/679. In this case, this circumstance constitutes the essence of the violation itself – it is not merely a factor influencing – either aggravating or mitigating – its assessment. For this reason, the lack of appropriate technical and organizational measures referred to in Article 32 of Regulation 2016/679 cannot be regarded in this case as a circumstance that could additionally influence the assessment of the violation and the amount of the administrative monetary penalty imposed on the Data Processor.

3. Any relevant prior violations by the administrator (Article 83(2)(e) of Regulation 2016/679). The President of the UODO did not find any violations on the part of Ms. CD, Mr. EF, and Mr. GH, thus the former and current partners of Y s.c., Al. (...)

of any previous violations of personal data protection regulations, which means there are no grounds to treat this circumstance as aggravating. It is the duty of each data processor to comply with the law, and therefore the absence of previous violations cannot also be considered a mitigating circumstance when imposing sanctions.

4. The degree of cooperation with the supervisory authority in order to remedy the violation and mitigate its potential negative effects (Article 83(2)(f) of Regulation 2016/679). During the proceedings, the former and current partners of Y s.c. did not undertake any additional actions in connection with the supervisory authority's inquiries. However, prior to the initiation of these proceedings, the aforementioned individuals took independent actions aimed at eliminating the source of the personal data protection violation. These actions – referenced on pages 14 and 15 of the justification for this decision – were, however, of an autonomous nature, and thus the President of UODO cannot treat them as taken in cooperation with the authority and cannot assess the "degree" of that cooperation in this regard. Regardless, these actions have been taken into account above and classified by the supervisory authority as a neutral circumstance defined in Article 83(2)(c) of Regulation 2016/679.

5. The manner in which the supervisory authority became aware of the violation, in particular, whether and to what extent the administrator reported the violation (Article 83(2)(h) of Regulation 2016/679). The President of UODO found that the data processor violated personal data protection regulations as a result of a report of a personal data breach made by the Administrator. By making the report, the Administrator was fulfilling a legal obligation, and therefore there are no grounds to consider this fact as a mitigating circumstance. The EDPB in Guidelines 04/2022 indicates that "the manner in which the supervisory authority became aware of the violation may constitute a significant aggravating or mitigating circumstance. In assessing this aspect, particular importance can be attributed to whether the administrator or the data processor notified the supervisory authority of the violation on their own initiative, and if so, to what extent, before the supervisory authority was informed of the violation through – for example – a complaint or proceedings. This circumstance is irrelevant when the administrator is subject to specific obligations regarding the reporting of violations (such as the obligation to report a personal data breach specified in Article 33 of the GDPR). In such cases, the fact of making a report should be considered a neutral circumstance."

6. Compliance with previously applied measures in the same case, as referred to in Article 58(2) of Regulation 2016/679 (Article 83(2)(i) of Regulation 2016/679). Prior to issuing this decision, the President of UODO did not apply any of the measures listed in Article 58(2) of Regulation 2016/679 against the data processor in the case at hand, and therefore it had no obligation to take any actions related to their application, which actions, if assessed by the supervisory authority, could have had an aggravating or mitigating impact on the assessment of the established violation.

7. The application of approved codes of conduct under Article 40 or approved certification mechanisms under Article 42 (Article 83(2)(j) of Regulation 2016/679). The data processor does not apply approved codes of conduct or approved certification mechanisms referred to in the provisions of Regulation 2016/679. However, their adoption, implementation, and application are not – as stipulated by the provisions of Regulation 2016/679 – mandatory for processors, which means that the circumstance of their non-application cannot be considered detrimental to Ms. CD, Mr. EF, and Mr. GH, i.e., the former and current partners of Y s.c. On the other hand, the circumstance of adopting and applying such instruments could be taken into account in favor of the aforementioned individuals as measures

guaranteeing a higher than standard level of protection for personal data processing.

8. Financial benefits gained directly or indirectly in connection with the violation or avoidance of loss (Article 83(2)(k) of Regulation 2016/679). The President of UODO did not find that in connection with the subject violation, Ms. CD, Mr. EF, and Mr. GH gained any financial benefits or avoided such losses. Therefore, there are no grounds to treat this circumstance as aggravating in relation to the former and current partners of Y s.c. The establishment of measurable financial benefits resulting from the violation of the provisions of Regulation 2016/679 should be assessed very negatively. The absence of such benefits for the aforementioned individuals, as a natural state independent of the violation and its effects, is a circumstance that inherently cannot be mitigating for the data processor. This interpretation is confirmed by the very wording of Article 83(2)(k) of Regulation 2016/679, which requires the supervisory authority to pay due attention to the benefits "gained" – that occurred on the part of the entity committing the violation.

9. Other aggravating or mitigating factors applicable to the circumstances of the case (Article 83(2)(k) of Regulation 2016/679). The President of UODO, comprehensively considering the case, did not note any circumstances other than those described above that could influence the assessment of the violation and the amount of the imposed administrative fine. Taking into account all the circumstances discussed above, the President of the Personal Data Protection Office concluded that imposing an administrative fine on the data processor is necessary and justified by the weight, nature, and scope of the violations attributed to this entity under Regulation 2016/679. It should be stated that the application of any other remedial measure against these entities...

provided for in Article 58(2) of Regulation 2016/679, in particular, the mere issuance of a warning (Article 58(2)(b) of Regulation 2016/679) would not be proportional to the identified irregularities in the processing of personal data and would not guarantee that the aforementioned entities would not commit similar negligence in the future, as in this case.

V. Method of calculating the fine against the Data Processor based on Guidelines 04/2022 on calculating administrative monetary penalties under the GDPR.

It is necessary to indicate that in determining the amount of the administrative monetary penalty against the Data Processor in this case, the President of the UODO applied the methodology adopted by the European Data Protection Board in Guidelines 04/2022. According to the guidance presented in this document:

1. The President of the UODO categorized the identified violations of the provisions of Regulation 2016/679 in this case (see Chapter 4.1 of Guidelines 04/2022). The violation of Article 28(3)(f) in connection with Article 32(1) and (2) of Regulation 2016/679 identified in this case falls – according to Article 83(4)(a) of Regulation 2016/679 – into the category of violations subject to a lower penalty of the two penalties provided for in Regulation 2016/679 (with a maximum amount of up to EUR 10,000,000 or up to 2% of the total annual turnover of the enterprise from the previous financial year). It has therefore been considered in abstracto (independently of the individual circumstances of the specific case) by the EU legislator as less serious than the violations indicated in Article 83(5) of Regulation 2016/679.

2. The President of the UODO assessed the violation identified in this case as a violation of low severity (see Chapter 4.2 of Guidelines 04/2022). In this assessment, the factors among those listed in Article 83(2) of Regulation 2016/679 that pertain to the subject of the violation (constituting the "seriousness" of the violation) were taken into account, namely: the nature, gravity, and duration of the violation (Article 83(2)(a) of Regulation 2016/679), the intentional or unintentional nature of the violation (Article 83(2)(b) of Regulation 2016/679), and the categories of personal data affected by the violation (Article 83(2)(g) of Regulation 2016/679). A detailed assessment of these circumstances has been presented above. It should be noted here that considering their cumulative impact on the assessment of the violation identified in this case leads to the conclusion that the level of its severity in concreto is low (on the scale of severity of violations presented in point 60 of Guidelines 04/2022). Consequently, this results in the acceptance – as the starting amount for calculating the fine – of a

value falling within the range of 0 to 10% of the maximum amount of the fine that can be imposed on the Data Processor. Given that Article 83(4) of Regulation 2016/679 obliges the President of the UODO to adopt as the maximum amount of the fine for the violation indicated in this provision the amount of EUR 10,000,000 or – if this amount is higher than EUR 10,000,000 – the amount representing 2% of the Data Processor's turnover from the previous financial year, the President of the UODO concluded that the so-called static maximum amount of the fine applies in this case, i.e., EUR 10,000,000, which is higher than the amount resulting from the application of the 2% rate applied to the Data Processor's turnover for 2023, which amounted to (...) EUR. Having at his disposal a range from EUR 1,000,000 to EUR 2,000,000, the President of the UODO accepted, as adequate and justified by the circumstances of the case, the starting amount for calculating the fine to be (...) EUR (constituting (...) % of the static maximum amount of the fine).

3. The President of the UODO adjusted the starting amount corresponding to the low severity of the identified violation to the turnover of the Data Processor as a measure of its size and economic strength (see Chapter 4.3 of Guidelines 04/2022). According to Guidelines 04/2022, in the case of enterprises whose annual turnover is less than or equal to EUR 2 million, the supervisory authority may consider making further calculations of the amount of the fine based on a value falling within the range of 0.2% to 0.4% of the starting amount. Given that the turnover of the Data Processor in 2023 amounted to (...) PLN, which is (...) EUR (according to the average exchange rate of EUR on January 29, 2024), the President of the UODO deemed it appropriate to adjust the amount subject to calculations to a value corresponding to (...) % of the starting amount, that is to the amount of (...) EUR (equivalent to (...) PLN).

4. The President of the UODO assessed the impact on the identified violation of other circumstances (besides those taken into account above in the assessment of the severity of the violation) indicated in Article 83(2) of Regulation 2016/679 (see Chapter 5 of Guidelines 04/2022). These circumstances, which may have an aggravating or mitigating effect on the assessment of the violation, relate – as assumed by Guidelines 04/2022 – to the subjective side of the violation, that is, to the entity itself that committed the violation and to its behavior before the violation, during it, and after it occurred. A detailed assessment and justification of the impact of each of these factors on the assessment of the violation have been presented above. The President of the UODO concluded (as justified in the above-presented part of the reasoning of the decision) that the remaining factors from Article 83(2)(c), (d), (e), (f), (h), (i), (j), (k) of Regulation 2016/679 – as indicated above – did not have any impact, either mitigating or aggravating, on the assessment of the violation and consequently on the amount of the fine. Due to the absence of additional mitigating or aggravating circumstances related to the subjective side of the violations (the assessment of the Data Processor's conduct before and after the violations), the President of the UODO deemed it appropriate to maintain the amount of the fine determined based on the assessment of the severity of the violation (point 2 above) at the unchanged level of EUR 2,250.

5. The President of the UODO (Personal Data Protection Office) has determined that the amount of the aforementioned fine does not require additional adjustment due to the principle of proportionality mentioned in Article 83(1) of Regulation 2016/679, which is one of the three directives for penalty assessment (see Chapter 7 of Guidelines 04/2022). The monetary penalty of an amount equivalent to 2,250 EUR will be effective (due to its severity, it will achieve its repressive goal of punishing unlawful behavior) and deterrent (effectively discouraging both the Data Processor and other processors from committing violations of the provisions of Regulation 2016/679 in the future). The principle of proportionality requires, among other things, that the measures adopted by the supervisory authority do not exceed what is appropriate and necessary to achieve legitimate objectives (see points 137 and 139 of Guidelines 04/2022). In other words: "A sanction is proportional if it does not exceed the threshold of severity determined by taking into account the circumstances of the specific case" (P. Litwiński (ed.), Regulation of the European Parliament and of the Council (EU) 2016/679 of April 27, 2016 [...]; Commentary on Article 83 [in:] P. Litwiński (ed.) General Data Protection Regulation. Data Protection Act. Selected Sectoral Provisions. Commentary). The amount of 9,822 PLN, equivalent to 2,250 EUR, constitutes a threshold above which any further increase in the amount of the fine would

not, in the opinion of the President of the UODO, be associated with an increase in its effectiveness and deterrent nature. On the other hand, a greater reduction in the amount of the fine could occur at the expense of its effectiveness and deterrent nature, as well as the consistent application and enforcement of Regulation 2016/679 and the principle of equal treatment of entities in the EU and EEA internal market.

VI. Directives of effectiveness, proportionality, and deterrent nature applied to the sanction imposed on the Data Processor (Article 83(1) of Regulation 2016/679).

In the opinion of the President of the UODO, the administrative monetary penalty imposed on Mr. EF and Mr. GH, partners of Y s.c., Al. (...), and Ms. CD, a former partner of Y s.c., all jointly liable, fulfills in the established circumstances of this case the functions referred to in Article 83(1) of Regulation 2016/679, i.e., it is effective, proportional, and deterrent in this individual case.

The penalty will be effective if its imposition leads to the Data Processor fulfilling its obligations regarding personal data protection in the future, particularly concerning the implementation of appropriate technical and organizational measures that adequately mitigate the risk of a personal data breach.

In the opinion of the President of the UODO, the administrative monetary penalty will serve a repressive function, as it will be a response to the Data Processor's violation of the provisions of Regulation 2016/679. It will also serve a preventive function, as it will indicate both to this specific Data Processor and to other processors the seriousness of neglecting their duties related to assisting controllers in fulfilling their obligations specified in Articles 32-36 of Regulation 2016/679.

Pursuant to Article 103 of the UODO, the amounts expressed in euros referred to in Article 83 of Regulation 2016/679 are calculated in PLN according to the average euro exchange rate announced by the National Bank of Poland in the exchange rate table on January 28 of each year, and if the National Bank of Poland does not announce the average euro exchange rate on January 28 of a given year – according to the average euro exchange rate announced in the nearest exchange rate table after that date.

Taking the above into account, the President of the UODO, based on Article 83(4)(a) in connection with Article 103 of the UODO, for the violation described in the operative part of this decision, imposed on the Data Processor – using the average euro exchange rate from January 29, 2024 (1 EUR = 4.3653 PLN) – an administrative monetary penalty in the amount of 9,822 PLN (which constitutes the equivalent of 2,250 EUR).

In the opinion of the President of the UODO, the imposed monetary penalty of 9,822 PLN (in words: nine thousand eight hundred twenty-two zlotys) meets the conditions referred to in Article 83(1) of Regulation 2016/679 in the established circumstances of this case due to the seriousness of the identified violation in the context of the fundamental objective of Regulation 2016/679 – the protection of fundamental rights and freedoms of natural persons, particularly the right to personal data protection. Referring to the amount of the administrative monetary penalty imposed on the Data Processor, the President of the UODO found that it is proportional to the financial situation of the Data Processor and will not constitute an excessive burden for it.

From the information provided by the Data Processor “(...)”, it follows that the revenue for the year 2023 amounted to (...) PLN, which means that the amount of the administrative monetary penalty imposed in this case constitutes approximately (...) % of the aforementioned value. At the same time, it is worth emphasizing that the amount of the imposed penalty of 9,822 PLN is merely (...) % of the maximum amount of the penalty that the President of the UODO could – in accordance with Article 83(4) of Regulation 2016/679, with a maximum penalty of up to 10,000,000 EUR – impose on the Data Processor for the violation identified in this case.

The amount of the penalty has been set at such a level that, on the one hand, it constitutes an adequate response from the supervisory authority to the degree of violation of the Data Processor's obligations, while on the other hand, it does not create a situation in which the necessity to pay a

financial penalty would lead to negative consequences, such as a significant reduction in employment or a substantial decrease in its...

turnover. According to the President of the Personal Data Protection Office (UODO), the Data Processor should and is able to bear the consequences of its negligence in the area of data protection, as evidenced by “(...)”, the content of which was disclosed to the President of UODO on March 15, 2024.

In summary, in the opinion of the President of UODO, both administrative monetary penalties imposed in this case meet, in light of the overall individual circumstances of the case, the criteria (functions of penalties) referred to in Article 83(1) of Regulation 2016/679, due to the severity of the identified violations in the context of the fundamental requirements and principles of Regulation 2016/679.

Having considered the above, the President of the Personal Data Protection Office has decided as stated in the operative part of this decision.

Print article

Metadata

Provider:

Department of Control and Violations

Created by:

Mirosław Wróblewski

2024-10-09

Entered by:

Wioletta Golańska

2024-10-22 14:51:03

Last modified by:

Agnieszka Kaczor

2024-11-12 14:59:27